Tecnológico de Monterrey · TC2007B · Bloque con Sentido Humano

Entrega 3 · Documento final

Familias que Suman: aplicación móvil y servicio

PROYECTO

Familias que Suman · aplicación móvil Android y servicio en la nube

EQUIPO

Equipo 6 · Grupo 402

SOCIO FORMADOR

Familias que Suman

INTEGRANTES

Bárbara Martínez Mijares · A01723424
Gael Alexander Zaragoza Torres · A01385956
Damaris Paola Castrellón Carrillo · A01234497
Alberto López Barragán · A00841178
José Andrés Fajardo Martínez · A00842793

PROFESORES

Rolando Evelio Pérez Versón
Juan David Guarnizo Hernandez
Aída Judith Gándara Tovar

FECHA

22 de octubre de 2026

Etiqueta del repositorio: entrega-final · APK 3.2 · github.com/albertolopezb/familias-que-suman

Contenido

1. Resumen del alcance final y referencia al acta de acuerdos

2. Arquitectura final del sistema

3. Matriz de trazabilidad y evidencia de pruebas

4. Evidencia de los controles de seguridad

5. Manual de usuario

6. Manual de instalación

7. Plan de implantación

8. Administración final del proyecto

9. Consideraciones éticas y legales

10. Enlaces de la entrega

1. Resumen del alcance final y referencia al acta de acuerdos

Familias que Suman conecta a familias con asociaciones, actividades de voluntariado y campañas de donación en Monterrey y Hermosillo. Ya tiene un sitio web. La socia formadora pidió que la app aporte lo que el teléfono hace mejor:

- avisos que llegan solos (recordatorios y urgencias de la ciudad);
- contacto directo por WhatsApp, llamada y correo;
- una sesión que se queda abierta para consultar perfil, historial e insignias sin entrar cada vez.

La solución es una **app Android nativa** (Kotlin, Jetpack Compose) conectada a una **API propia** (FastAPI y PostgreSQL en Docker). La API se publica en internet por un túnel HTTPS de Cloudflare desde una VM de Microsoft Azure pagada con el crédito de Azure for Students (sin costo para el equipo).

1.1 Acuerdos con el socio formador y cómo se cumplieron

Sobre el acta de acuerdos. No existe un acta independiente firmada con el socio formador. El acuerdo de alcance quedó en dos documentos, que son los que esta entrega toma como referencia:

- **Requerimientos Iniciales Validados** (RF-01 a RF-15, con su columna «Decisión del socio formador»), el documento que el profesor publicó en Canvas.
- **Requerimientos Equipo 6**, la versión ampliada del equipo: RF-01 a RF-23, casos de uso, preguntas y respuestas con la representante del socio formador, historias de usuario y el enlace al backlog en Planner: https://docs.google.com/document/d/1E9YGMQR1R2KuULSeeNgVbwip-9pn6ljhmjwBu2FMb7o

RF-24 a RF-29 se agregaron al backlog durante el desarrollo; en la matriz (§3) se indica su origen.

Lo que pidió el socio formador (requerimientos validados y sesiones con su representante):

Pedido	Cómo quedó	Evidencia
Consulta de proyectos y campañas activos, con filtrado por categoría y detalle	Pestañas Proyectos, Donar (filtros por categoría y urgencia) y Directorio, con ficha de cada uno	RF-09, RF-20
Contacto directo con la asociación en un toque	Botones de llamada, WhatsApp, correo e Instagram en las fichas, que abren la app correspondiente con el dato puesto	RF-08
Una app que aproveche el teléfono: avisos que llegan solos y una sesión que se queda abierta	Recordatorio 24 h antes y avisos de la ciudad con la app cerrada (WorkManager); sesión cifrada que se renueva sola	RF-16, RF-18, RF-22

Lo que agregó el equipo (no venía de los requerimientos del socio):

Decisión	Cómo quedó	Evidencia
Consulta de fichas sin conexión	El catálogo público se guarda en el teléfono (Room); sin internet se ve lo guardado, con aviso de la fecha y sin presumir cupo	RF-29, `CatalogoLocalTest`
Comunicación cifrada HTTPS/TLS y autenticación con tokens JWT	Pedidas por la rúbrica de seguridad de la Entrega 3 y el curso: TLS 1.2/1.3 en todo el camino público; JWT propio de 15 min con refresh rotado	SEG-01, SEG-07

1.2 Qué entra

- App Android en español (Android 8 o superior; la meta del backlog es Android 10+).
- Directorio de asociaciones y centros por categoría, filtro por ciudad (Monterrey y Hermosillo), "Buscar cerca de" un lugar en el mapa (sin pedir la ubicación), fichas y contacto directo.
- Actividades con cupo en tiempo real, inscripción con acompañantes (consentimiento del tutor para menores), cancelación hasta 12 horas antes y "Agregar al calendario".
- Campañas de donación con filtros y apartado de artículos con meta en tiempo real. La donación es informativa: la app no procesa pagos.
- Cuenta con registro diferido (explorar no pide cuenta), recuperación de contraseña con código por correo y sesión persistente cifrada.
- Perfil, historial, favoritos que avisan de lo nuevo, insignias, métricas de impacto, testimonios con foto (galería o cámara) revisados antes de publicarse, encuestas antes y después, ajustes y aviso de privacidad con solicitud de eliminación.
- Recordatorio 24 h antes y avisos personalizados (urgencias de la ciudad, actividades nuevas) con la app cerrada.
- Administración en la app, según permisos:
- crear, editar, duplicar y borrar actividades, proyectos, campañas, centros y asociaciones;
- revisar testimonios y sugerencias;
- enviar avisos;
- ver quiénes van a cada actividad;
- atender solicitudes de eliminación de datos.
- Backend propio en contenedores, con monitoreo (Prometheus y Grafana), pruebas automáticas y escaneo OWASP ZAP.

1.3 Qué no entra

- Pagos o donativos en línea.
- Mensajería entre familias: el único canal es familia ↔ asociación.
- iOS.
- Rastreo de ubicación y alertas por cercanía con GPS (*geofencing*). La app no pide la ubicación: "Buscar cerca de" usa un lugar que la familia escribe o toca en el mapa (dilema 1, §9.4).
- Modo sin conexión completo: sin internet se **consulta** lo guardado. Inscribirse, apartar y todo lo que cambia algo requiere conexión, porque el cupo y las metas se deciden en el servidor.
- Notificaciones instantáneas por Firebase: los avisos llegan con WorkManager, con hasta ~15 min de retraso.

1.4 Operación sin conexión y sincronización posterior

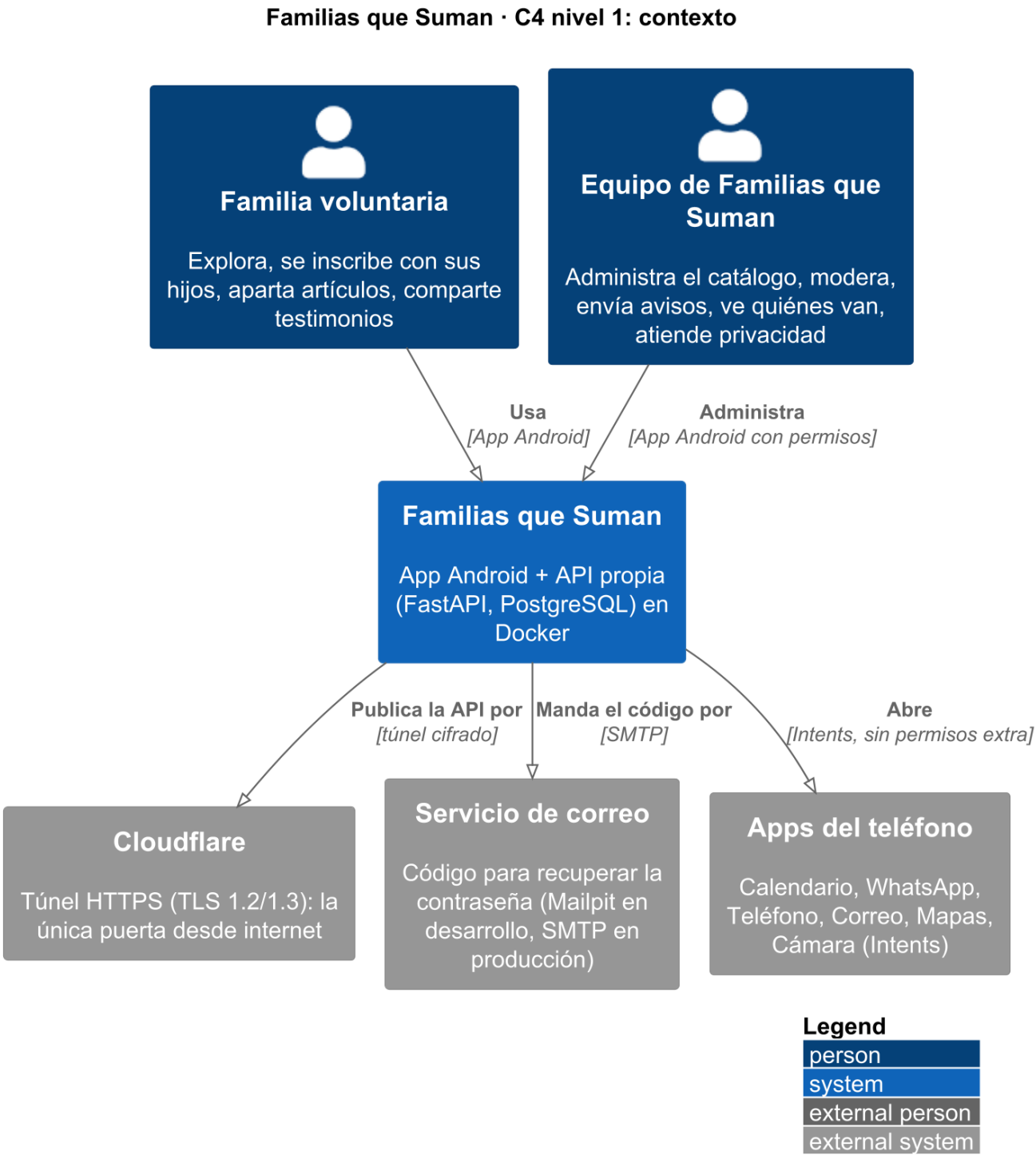
La rúbrica pide que, si hay operación sin conexión, la sincronización posterior evite duplicados o pérdida de información. En esta entrega el modo sin conexión es de **solo lectura**: se guarda y se consulta el catálogo público, y lo único que el teléfono escribe sin red es esa copia de lo ya publicado, que la respuesta nueva del servidor reemplaza completa cuando vuelve la red.

Todo lo que cambia datos (inscribirse, cancelar, apartar artículos, testimonios) **requiere conexión** y se decide en el servidor. Por eso **no hay cola de operaciones pendientes ni sincronización posterior: no hay nada que pueda duplicarse o perderse al volver la red**. Y aun con una red inestable, los reintentos no duplican: inscribirse es un `PUT` idempotente (la misma petición dos veces deja una sola inscripción) y apartar artículos nunca pasa de lo que falta (RF-21, `test_aportaciones.py`; RF-05 y RF-06, `test_inscripciones.py`).

2. Arquitectura final del sistema

Modelo C4 en tres niveles: contexto, contenedores y componentes. Las imágenes se generan con C4-PlantUML desde `docs/entrega-3/diagramas/*.puml`.

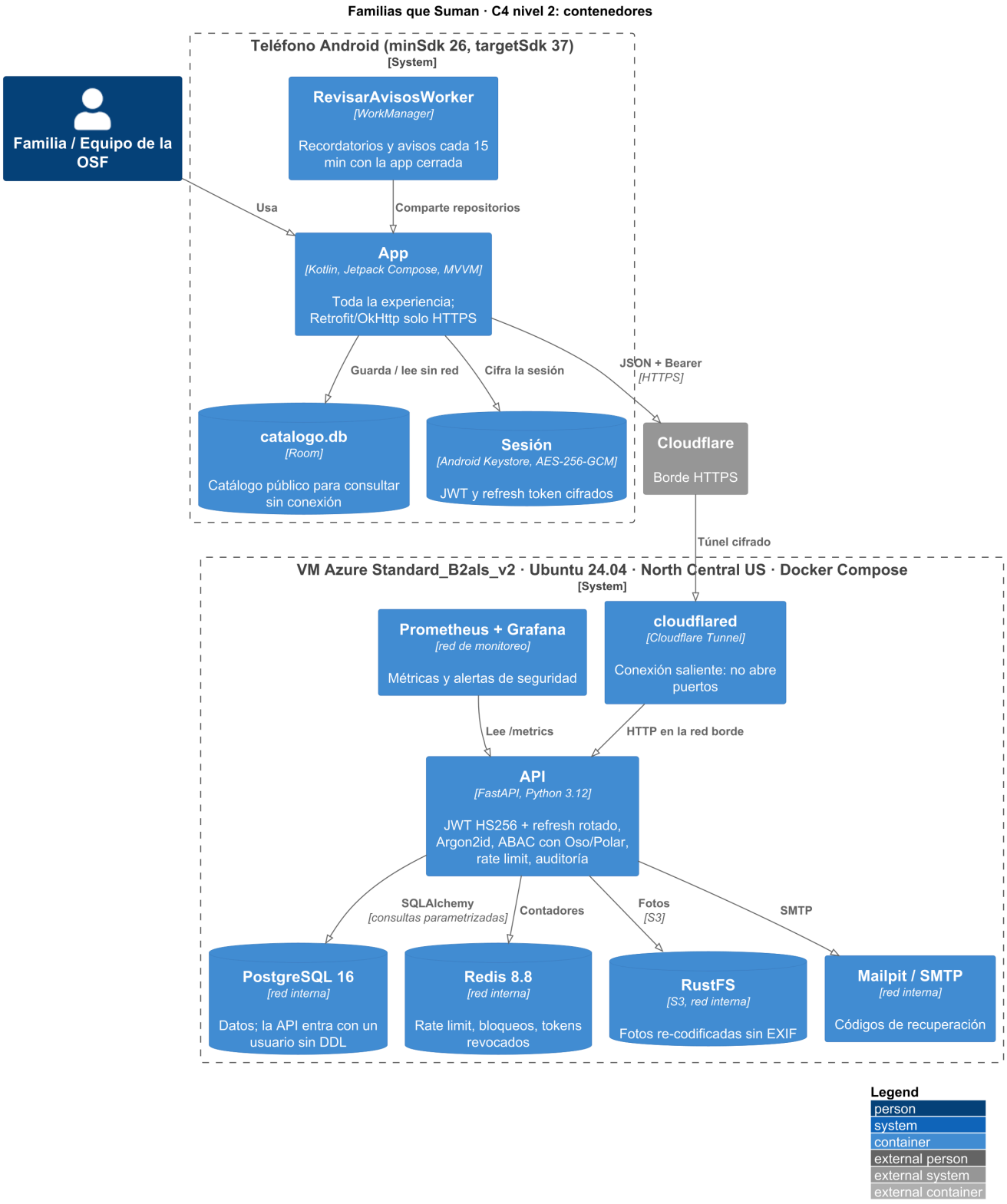
2.1 Nivel 1 · Contexto



- **Quién lo usa:** familias de Monterrey y Hermosillo (sin cuenta para explorar; con cuenta para inscribirse) y el equipo de Familias que Suman (cuentas con permisos firmados en su token).

- **Qué no hace:** no procesa pagos, no tiene mensajería entre familias, no usa Firebase ni Google Play Services, no rastrea la ubicación.

2.2 Nivel 2 · Contenedores

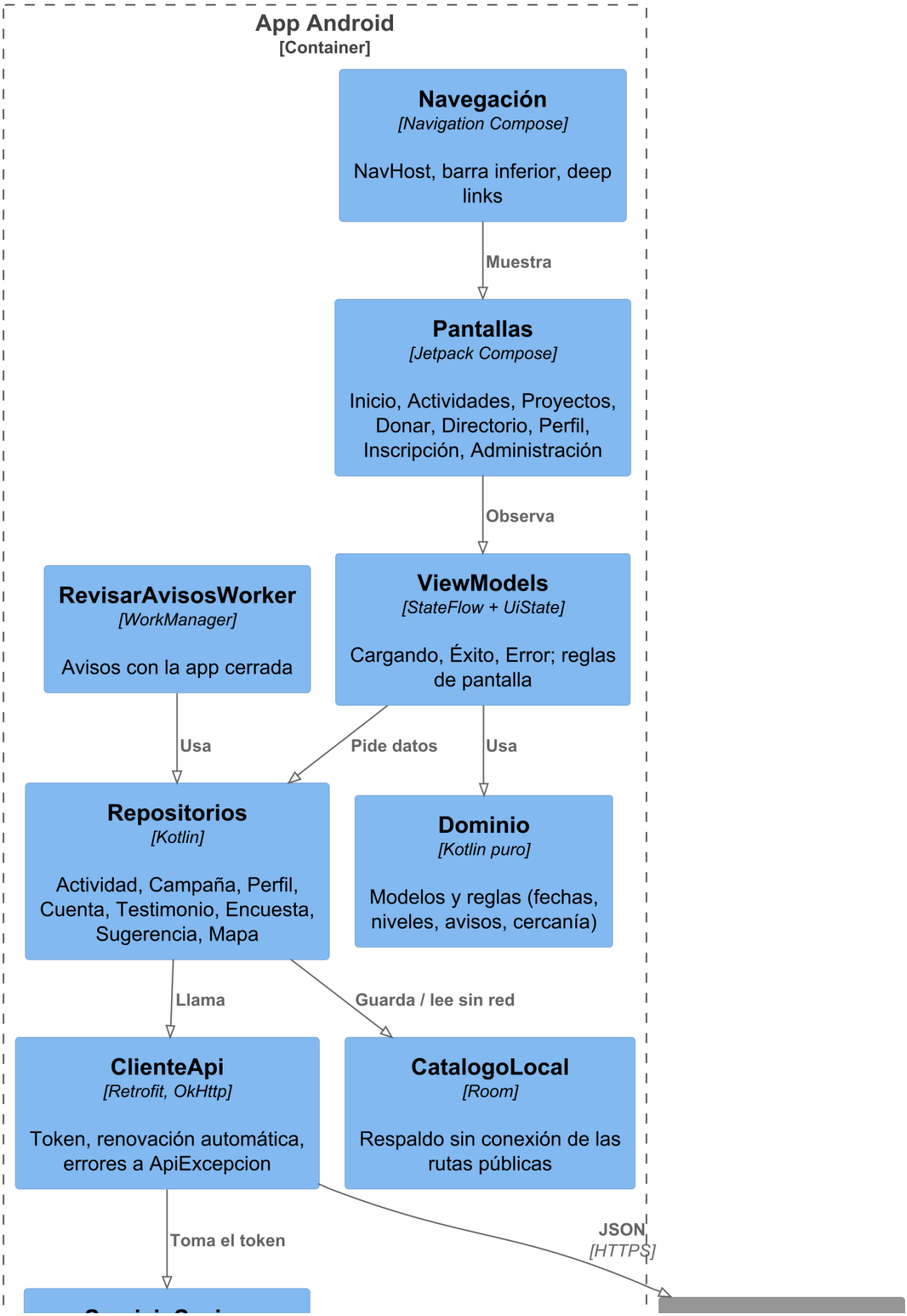


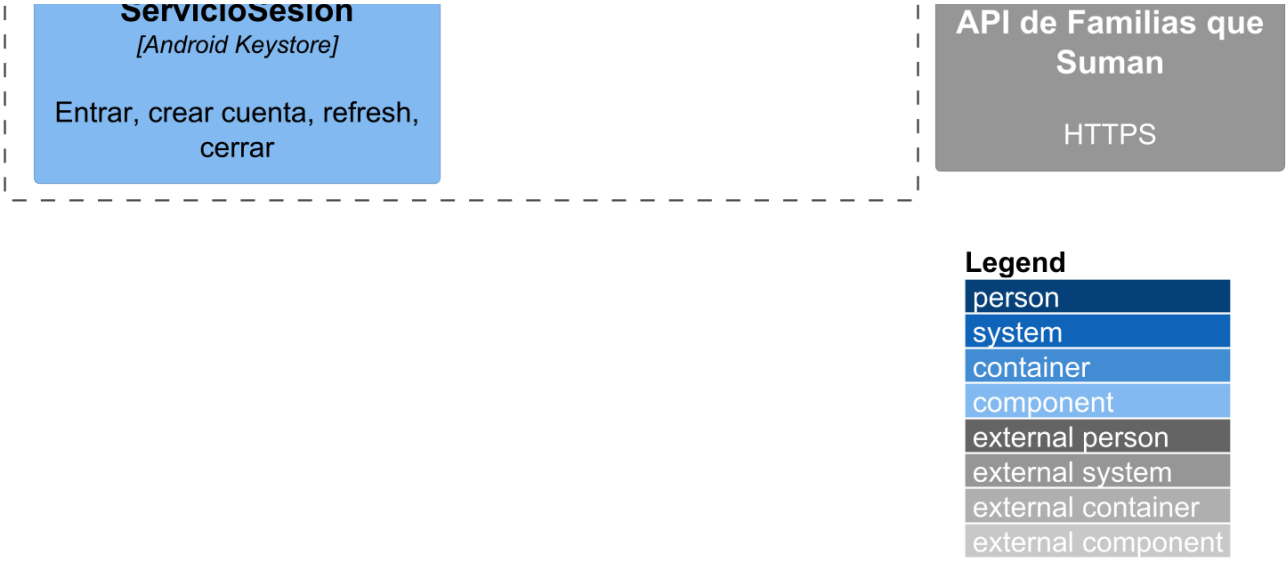
Contenedor	Tecnología	Responsabilidad
App	Kotlin, Compose, Material 3	Toda la experiencia de la familia y de la administración; guarda el catálogo público (Room) y la sesión cifrada (Keystore)

Contenedor	Tecnología	Responsabilidad
cloudflared	Cloudflare Tunnel	Única puerta desde internet; conexión saliente, sin puertos abiertos en el servidor
API	FastAPI	Identidad (registro, inicio, refresh rotado, cierre, recuperación), autorización ABAC, catálogo, inscripciones con cupo atómico, campañas, testimonios con revisión, encuestas, avisos, privacidad, auditoría
PostgreSQL	16	Datos de negocio; la API entra con un usuario sin permisos de DDL
Redis	8.8	Contadores de rate limit, bloqueo por fuerza bruta, tokens revocados
RustFS	S3 compatible	Fotos de perfil y testimonios, ya reducidas y sin metadatos
Flyway	11	Esquema versionado (`backend/db/migrations`)
Mailpit / SMTP	—	Código de 6 dígitos para recuperar la contraseña
Prometheus + Grafana	—	Métricas y alertas (picos de 401/403/429, entradas inválidas)

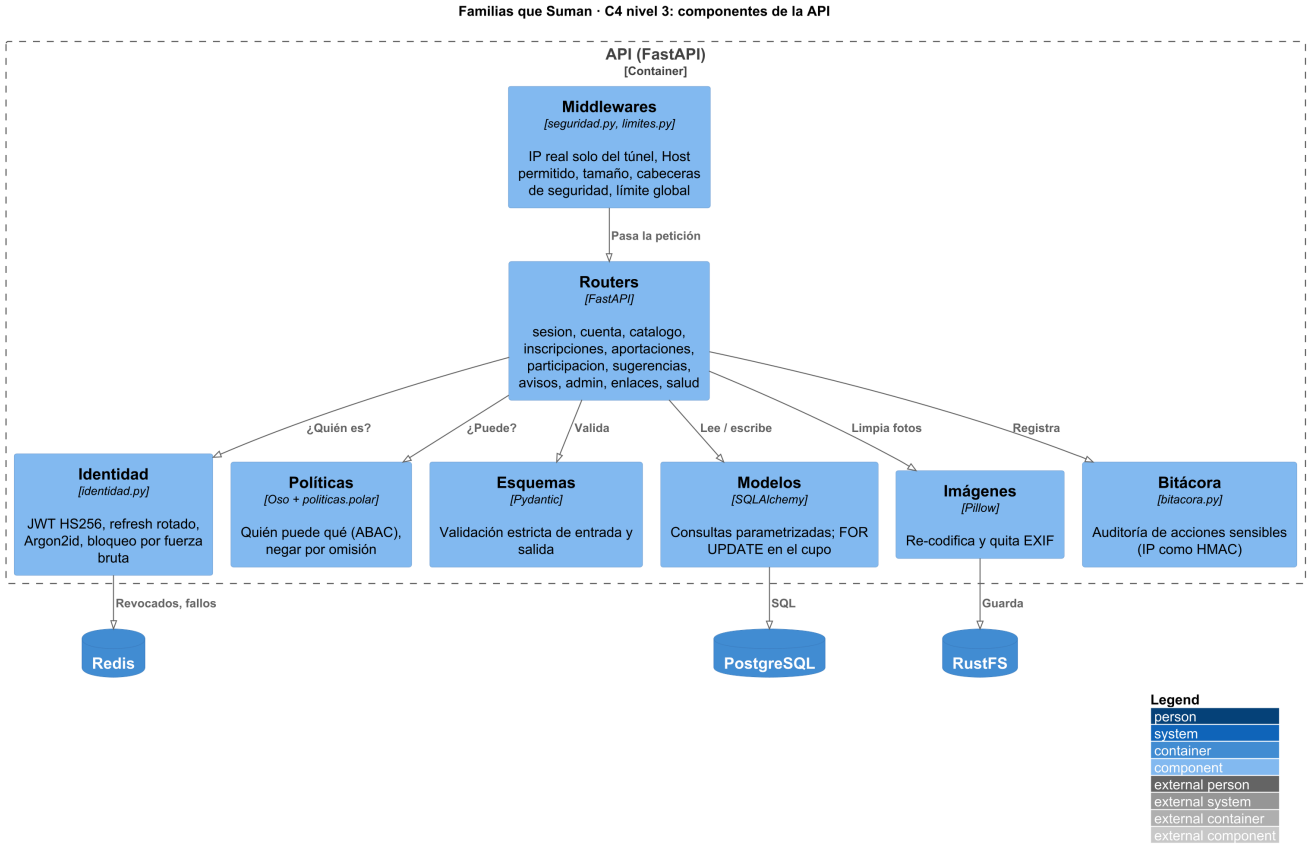
2.3 Nivel 3 · Componentes de la app

Familias que Suman · C4 nivel 3: componentes de la app





2.4 Nivel 3 · Componentes de la API



2.5 Decisiones técnicas principales

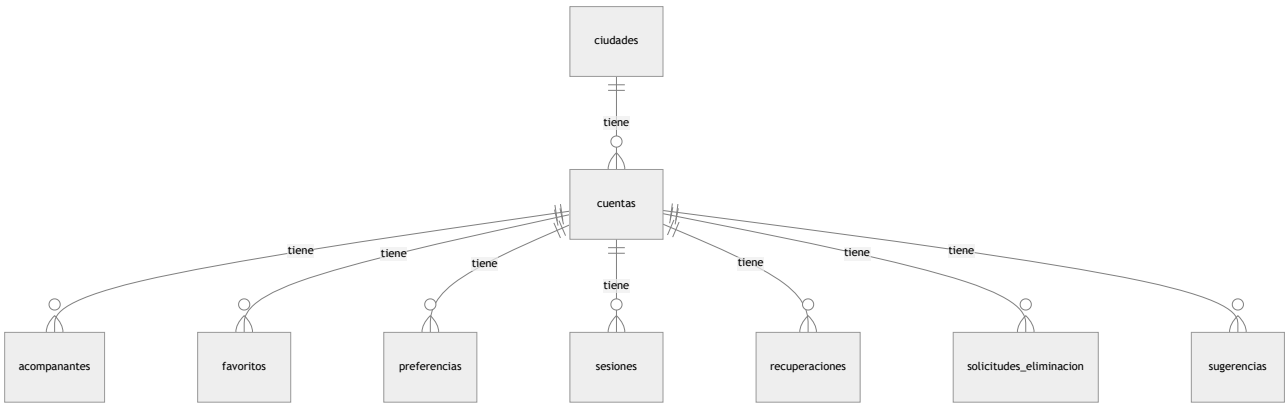
La bitácora completa, con fecha y razón de cada una, está en `docs/bitacora.md`.

Decisión	Alternativa descartada	Por qué
Android nativo con Kotlin y Jetpack Compose, una sola base de código	Multiplataforma	Lo del curso; acceso directo a WorkManager, Keystore e Intents; el alcance se acotó a Android
API propia en FastAPI con PostgreSQL, todo en Docker Compose	Backend como servicio (Firebase)	Control de los datos de menores, reproducible por cualquiera con `docker compose up`, sin cuentas externas
Identidad propia: JWT HS256 de 15 min + refresh token de 30 días rotado y de un solo uso	Auth0 (se usó del 13 al 15 de oct)	La guía de clase (s23) pide JWT propio; sin servicio externo que configurar; detecta el reuso de un refresh robado
Contraseñas con Argon2id y bloqueo de 15 min tras 5 fallos por correo	BCrypt / solo límite por IP	Primera opción de OWASP; un bot con muchas IP igual se frena
Autorización ABAC con Oso (Polar)	Roles fijos en cada ruta	Las reglas dependen de quién es dueño y de cuándo (12 h antes, edad mínima); quedan en un solo archivo revisable
Cupo con `SELECT … FOR UPDATE` dentro de la transacción	Contar en la app	Dos familias por el último lugar: solo una lo obtiene (RF-05)
Fotos a un almacén S3 (RustFS), re-codificadas sin EXIF	Guardarlas en la base / MinIO	La base solo guarda la clave; MinIO comunitario dejó de recibir parches
Avisos con WorkManager cada 15 min, sin Firebase	FCM	Práctica 8: sin cuentas de Google ni otra llave privada; el aviso de privacidad no tiene que declarar a Google. Costo: hasta ~15 min de retraso
Catálogo público guardado con Room para verlo sin conexión	Guardar todo, o nada	Consulta de fichas sin conexión (RF-29) sin guardar datos personales en el teléfono
Salida a internet por Cloudflare Tunnel	Abrir puertos / IP pública	HTTPS sin abrir puertos; la red de Cloudflare absorbe ataques de red
Servidor en una VM de Azure for Students (2 vCPU, 4 GB)	Oracle Cloud Always Free (rechazó la tarjeta en dos cuentas); Render/Railway (se duermen)	Sin tarjeta ni costo (crédito de estudiante), no se duerme y corre el mismo `docker compose`. La política de la suscripción solo permite regiones fuera de México: se eligió la más cercana y se declara en el aviso
Explorar sin cuenta; la cuenta se pide al inscribirse (registro diferido)	Pedir cuenta al abrir	RF-18: menos fricción y menos datos de quien solo mira
Donación solo informativa	Pagos en línea	Indicación de la socia; no se manejan datos de pago

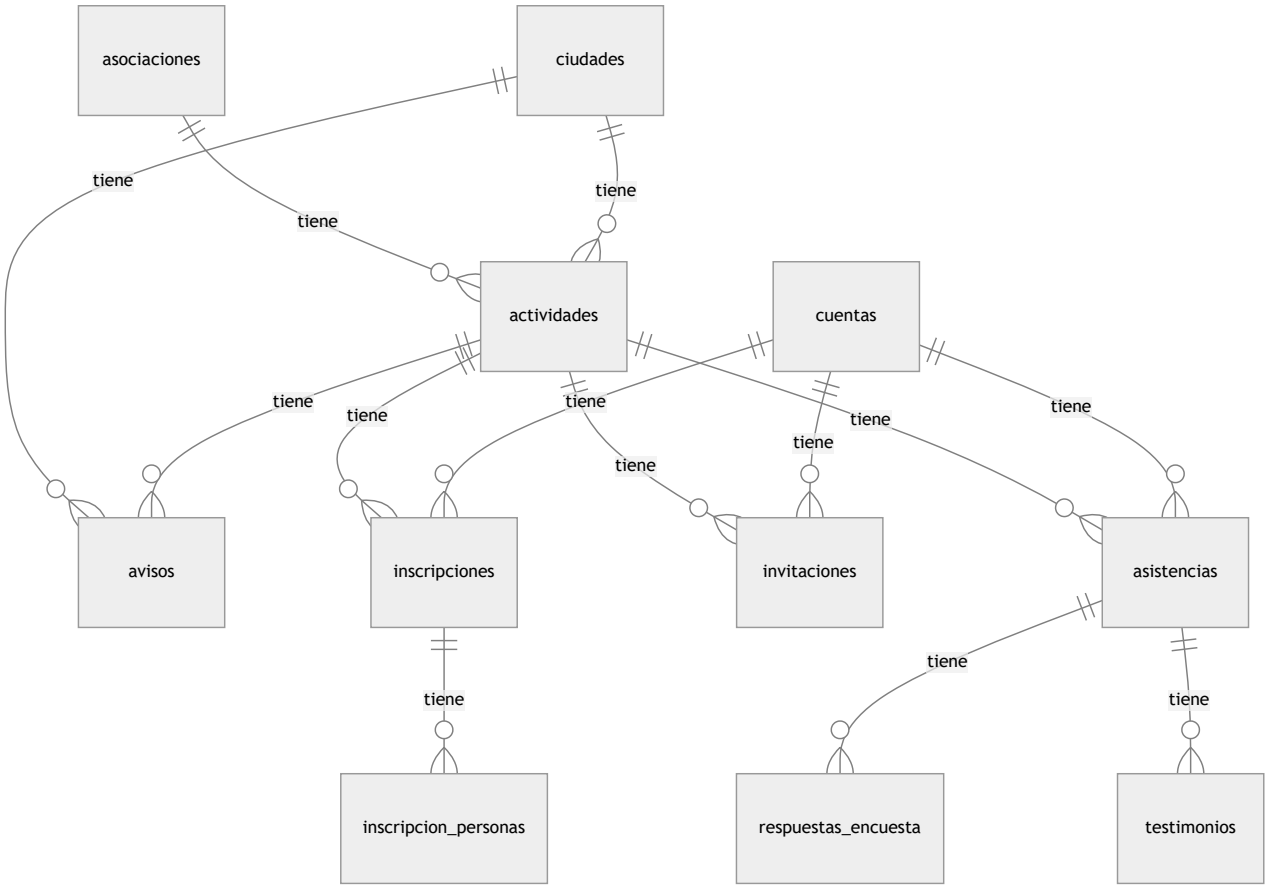
2.6 Modelo de datos (entidad-relación)

Las 27 tablas de PostgreSQL, creadas por las migraciones Flyway `V1` a `V11` (`backend/db/migrations/`), en tres diagramas para que se lean. Cada línea es una llave foránea, «uno a muchos» de la tabla de la izquierda a la de la derecha. `cuentas` y `ciudades` son el centro: casi todo lo que la familia hace cuelga de su cuenta, y todo el catálogo público se filtra por ciudad. Los atributos no se dibujan; están en la Guía del backend (§5) y en las migraciones.

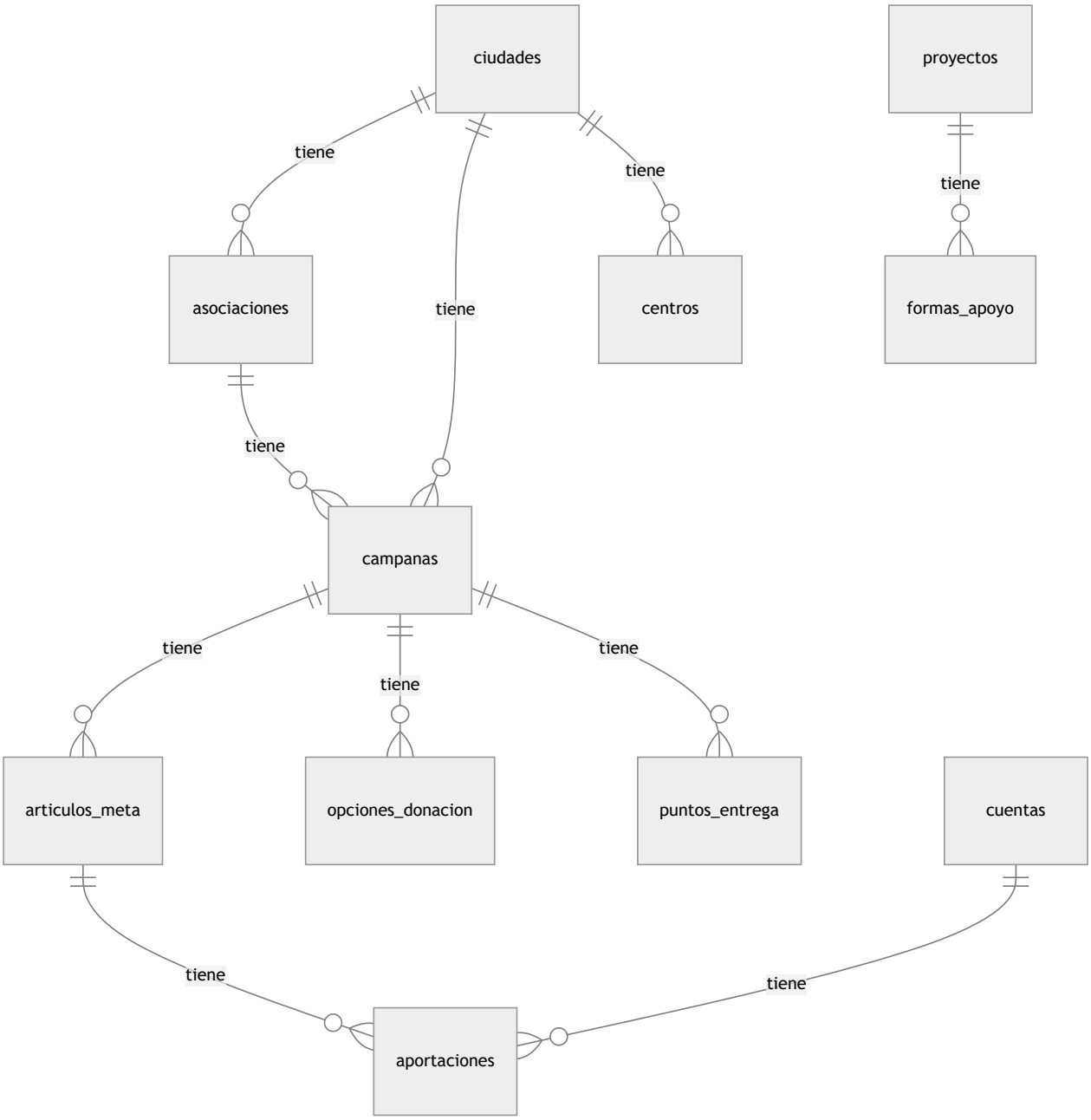
a) La familia y su cuenta



b) Actividades y participación



c) Catálogo y donaciones



La tabla `auditoria` no tiene llaves foráneas a propósito: guarda quién hizo qué con la identidad seudonimizada (HMAC de la IP), de modo que borrar una cuenta no obliga a borrar su rastro de seguridad.

3. Matriz de trazabilidad y evidencia de pruebas

Versión que respalda: tag `entrega-final` del repositorio. **Evidencia automática:**

- Servidor: 191 pruebas pytest contra PostgreSQL, Redis y RustFS reales → `docs/evidencia/pytest-servidor.txt`.
- App: 66 pruebas locales (JVM) → `docs/evidencia/pruebas-app.txt`, más 4 pruebas instrumentadas de Compose corridas en el teléfono físico → `docs/evidencia/pruebas-instrumentadas.txt`.
- Contrato de la API: `backend/smoke.sh`, 35 casos contra la API levantada → `docs/evidencia/smoke.txt`.
- Seguridad dinámica: OWASP ZAP sin y con sesión → `backend/seguridad/zap/reporte-zap.html`.
- Pruebas manuales en el teléfono físico (guion `M-xx` al final de esta sección).

Cada nombre de prueba se encuentra con Ctrl+F en el archivo de evidencia. Los ID son los del backlog en Planner (RF, RNF, HU y TT).

Cómo leer el estado:

- **Cumplido:** hay una prueba que lo demuestra y pasa.
- **Parcialmente cumplido:** pasa lo que se prueba, pero falta algo para que un usuario real lo tenga completo.
- **Pendiente:** no se ha podido demostrar.

> «Pasa» no es lo mismo que «Cumplido» (anexo de la Práctica 11): un requisito con sus pruebas en verde puede quedar parcial si a la persona usuaria todavía le falta algo.

3.1 Requerimientos funcionales

ID	Requisito	Criterio de aceptación (del backlog)	Prueba o evidencia	Resultado	Estado
RF-01	Directorio de asociaciones y centros por categoría	Una familia que abre la app por primera vez encuentra una causa que le interesa sin saber qué buscar	M-01; `smoke.sh` 2 "El catálogo es público"	Pasa (M-01, 2026-10-22)	Cumplido
RF-02	Filtro por ciudad y "cerca de mí", previa autorización	La familia ve primero lo que tiene cerca, sin compartir su ubicación: en el mapa escribe un municipio, colonia o calle (o toca un punto) y salen los tres lugares más cercanos con su distancia	`CercaniaTest` (6: distancia, orden, texto de la distancia, municipios sin internet, la familia de Apodaca, búsqueda en OpenStreetMap sin token); M-02	Pasan 6 de 6 + M-02 (2026-10-22)	Cumplido
RF-03	Ficha de la asociación	La familia decide si quiere ayudar sin salir de la app	M-03	Pasa (M-03, 2026-10-22)	Cumplido
RF-04	Actividades con fecha, horario, lugar, qué se hará y si es para niños	La familia sabe si la actividad le acomoda antes de inscribirse	M-04; `test_inscripciones.py::test_edad_minima_se_revisa_en_el_servidor`	Pasa (M-04, 2026-10-22)	Cumplido

ID	Requisito	Criterio de aceptación (del backlog)	Prueba o evidencia	Resultado	Estado
RF-05	Lugares disponibles en tiempo real	Si dos familias piden el último lugar a la vez, solo una lo obtiene y la otra recibe un aviso claro; nunca se sobrepasa el cupo	`test_inscripciones.py::test_toctou_varias_familias_a_la_vez_no_sobrepasan_el_cupo` (8 familias a la vez, `FOR UPDATE`), `::test_sin_lugares_suficientes`, `::test_inscribirse_descuenta_lugares`	Pasan 3 de 3	Cumplido
RF-06	Inscripción con acompañantes	La asociación recibe la lista de asistentes con el detalle que necesita	`::test_inscribirse_descuenta_lugares`, `::test_menores_piden_consentimiento`, `::test_quien_registra_asistencias_ve_quienes_van_sin_correos`, `::test_una_familia_o_el_admin_del_catalogo_no_ven_quienes_van`; M-06 (pantalla "Quiénes van")	Pasan 4 de 4	Cumplido
RF-07	Agregar al calendario	La familia recibe el recordatorio de su calendario el día de la actividad	M-07 en el teléfono (Intent `ACTION_INSERT` con título, inicio, fin y lugar)	Pasa M-07	Cumplido
RF-08	Contacto directo (llamada, WhatsApp, correo)	Contactar toma un toque, sin copiar números	M-08 en el teléfono	Pasa M-08	Cumplido
RF-09	Proyectos y campañas vigentes	La familia se entera de las campañas activas sin entrar al sitio web	M-09; `smoke.sh` 2-3	Pasa (M-09, 2026-10-22)	Cumplido
RF-10	Información para donar, sin pagos	La familia sabe qué llevar y a dónde	M-10; revisión: no hay pantalla ni dependencia de pagos en `app/build.gradle.kts`	Pasa (M-10, 2026-10-22): informativo, sin pantalla de pago	Cumplido
RF-11	Perfil e historial	La familia ve todo lo que ha hecho en el año	`test_participacion.py::test_historial_e_impacto_salen_de_las_asistencias`, `::test_una_familia_no_se_registra_asistencias`	Pasan 2 de 2	Cumplido
RF-12	Testimonio con foto, revisado antes de publicarse	Nada se publica sin que Familias que Suman lo apruebe	`test_testimonios.py` (6), entre ellas `::test_un_testimonio_nuevo_no_es_publico_hasta_aprobarlo` y `::test_rechazado_no_se_publica`; `TestimoniosYEncuestasTest` (12); `test_fotos.py::test_foto_valida_se_guarda_sin_exif`	Pasan 19 de 19	Cumplido
RF-13	Encuesta antes y después	Las respuestas quedan asociadas a la actividad y se consultan después	`test_participacion.py::test_encuesta_final_de_una_asistencia_propia`, `::test_encuesta_previa_pide_estar_inscrita`; `EncuestaViewModelTest` (6); `TestimoniosYEncuestasTest.lasRespuestasSeConsultanPorActividadYPorFamilia`	Pasan 9 de 9	Cumplido
RF-14	Reconocimiento (insignias y niveles)	La familia ve reflejado su recorrido	`FechasYNivelesTest.losNivelesSubenConLasActividades`; `test_historial_e_impacto_salen_de_las_asistencias` (sale de asistencias registradas, nadie se suma insignias)	Pasan 2 de 2	Cumplido

ID	Requisito	Criterio de aceptación (del backlog)	Prueba o evidencia	Resultado	Estado
RF-15	Aviso de privacidad accesible y solicitud de eliminación	Una mamá lo lee completo y entiende qué pasa con sus datos y los de sus hijos	`test_identidad.py::test_registro_pide_el_aviso_de_privacidad`; `test_participacion.py::test_solicitud_de_eliminacion_es_idempotente_y_la_atiende_privacidad`; M-15 (pedir la eliminación desde la app y atenderla en "Solicitudes de eliminación")	Pasan 2 de 2 + M-15	Cumplido
RF-16	Recordatorio 24 h antes	La familia inscrita recibe el recordatorio sin abrir la app	`AvisosTest.recuerda_el_dia_anterior_y_el_mismo_dia_pero_no_antes`, `::sin_el_interruptor_de_recordatorios_no_recuerda`, `::al_telefono_solo_de_dia_sin_leer_y_una_vez`; M-16 (WorkManager con la app cerrada)	Pasan 3 de 3; M-16 no se ejecutó, la entrega con la app cerrada se demostró en M-22 (2026-10-20)	Cumplido. Llega por WorkManager cada 15 min, no por FCM (ver desviaciones): puede tardar unos minutos más
RF-17	Favoritos que se actualizan	La familia guarda una asociación y la encuentra sin buscarla; se entera de lo nuevo	`AvisosTest.avisa_lo_nuevo_de_una_asociacion_favorita_si_no_estan_inscritos`, `::avisa_que_cierra_una_campana_favorita`; M-17	Pasan 2 de 2	Cumplido
RF-18	Cuenta con registro diferido y recuperación	Se recorre la app sin cuenta; al tocar "Inscribirme" se pide cuenta una vez y regresa a la misma actividad	`test_identidad.py::test_registro_crea_la_cuenta_y_entra`; `test_recuperacion.py` (8); `smoke.sh` 5-10 y 31-32; M-18	Pasan 9 de 9 + M-18	Cumplido
RF-19	Cancelar hasta 12 h antes; los lugares se liberan	Con menos de 12 h se rechaza; el contador sube de inmediato	`test_inscripciones.py::test_cancelar_libera_lugares`, `::test_no_se_cancela_a_menos_de_12_horas`; `test_politicas.py::test_cancelar_solo_hasta_12_horas_antes`	Pasan 3 de 3	Cumplido
RF-20	Filtrar campañas por categoría	Solo se ve lo que cumple el filtro	`TengoAlgoParaDonarViewModelTest.todosYTodasLasCategoriasConservanElFiltroExactoYOrden`; `TengoAlgoParaDonarUiTest.filtrosExpansionYAccionesEntreganLosDatosOriginales`; M-20	Pasan 2 de 2; M-20 (2026-10-22, APK 3.2)	Cumplido
RF-21	Apartar artículos de una campaña	No se aparta más de lo que falta; un reintento no cuenta doble	`test_aportaciones.py` (6): `::test_no_se_aparta_mas_de_lo_que_falta`, `::test_reintento_con_el_mismo_id_no_cuenta_doble` (idempotencia), `::test_campana_cerrada`	Pasan 6 de 6	Cumplido
RF-22	Avisos personalizados (intereses y urgencias de la ciudad)	La familia recibe urgencias de su ciudad y lo nuevo de lo que sigue	`test_avisos.py` (6): `::test_cada_familia_recibe_los_de_su_ciudad_y_los_generales`, `::test_una_actividad_nueva_genera_su_aviso`; `AvisosDelServidorTest` (2); M-22 (la administración envía un aviso y llega con la app cerrada)	Pasan 8 de 8 + M-22	Cumplido
RF-23	Métricas gráficas de impacto	La gráfica usa datos reales	`FechasYNivelesTest.cuentaLasActividadesPorMes`; `test_historial_e_impacto_salen_de_las_asistencias`	Pasan 2 de 2	Cumplido

ID	Requisito	Criterio de aceptación (del backlog)	Prueba o evidencia	Resultado	Estado
RF-24	Entrar como familia o como administración, con sus permisos	El perfil y los permisos corresponden al rol	`test_identidad.py::test_iniciar_sesion_da_un_jwt_con_los_atributos_de_la_cuenta`, `::test_nadie_se_registra_como_admin`, `::test_los_permisos_vienen_del_token_no_del_cuerpo`; `smoke.sh` 11, 14-16	Pasan	Cumplido
RF-25	Elegir acompañantes y ver lugares actualizados	(igual que RF-05 y RF-06)	Las de RF-05 y RF-06	Pasan	Cumplido
RF-26	Filtrar actividades por ciudad y categoría	Con Monterrey no aparece Hermosillo	M-26	Pasa M-26	Cumplido
RF-27	Corazón para guardar en Favoritos	Marcar y desmarcar se refleja en "Mis favoritos"	M-27; `PUT/DELETE /v1/yo/favoritos` idempotentes	Pasa (M-27, 2026-10-22)	Cumplido
RF-28	Cancelar desde Mis actividades liberando cupos	(igual que RF-19)	Las de RF-19	Pasan	Cumplido
RF-29	Consultar fichas de proyectos y actividades sin conexión (decisión del equipo, agregada al backlog)	Sin internet se ven las listas y fichas guardadas, con aviso de que son guardadas y sin presumir cupo	`CatalogoLocalTest` (6): `.sin_red_sale_lo_ultimo_guardado_y_se_avisa_de_cuando_es`, `.con_el_servidor_caido_tambien_sale_lo_guardado`, `.un_error_del_servidor_no_se_tapa_con_lo_guardado`, `.al_volver_la_red_desaparece_el_aviso_y_se_reemplaza_lo_guardado`; M-OFF (modo avión)	Pasan 6 de 6 + M-OFF (listas y franja)	Cumplido

3.2 Requerimientos no funcionales

ID	Requisito	Criterio	Prueba o evidencia	Resultado	Estado
RNF-01	Inicio y catálogo en menos de 1.5 s en el teléfono	Promedio de 10 aperturas < 1.5 s	M-RNF01: `adb shell am start -W` (TotalTime) y cronómetro del catálogo, en el teléfono físico	Arranque en frío: promedio 117 ms, máximo 148 ms (10 aperturas); catálogo visible en ~0.9 s contra el servidor de Azure	Cumplido
RNF-02	Sin contraseñas, tokens ni sesiones en claro (repo y logs)	Cero secretos en el código y el historial; nada sensible en Logcat	Búsqueda de secretos en el repositorio (gitleaks, `docs/evidencia/secretos.txt`); `test_identidad.py::test_la_contrasena_se_guarda_como_hash_argon2id`; `test_recuperacion.py::test_el_codigo_no_se_guarda_en_claro`; el token se guarda con AES-256-GCM del Android Keystore (`ServicioSesion.kt`); OkHttp sin interceptor de logs	Pasan	Cumplido
RNF-03	El estado sobrevive a la rotación	No se pierden datos al rotar a mitad de un formulario	ViewModel + `rememberSaveable` (la foto de la cámara también: `ElegirFoto.kt`); M-RNF03	Pasa (M-RNF03, 2026-10-22) en Crear cuenta; testimonio sin probar	Cumplido

ID	Requisito	Criterio	Prueba o evidencia	Resultado	Estado
RNF-04	Atrás no duplica pantallas ni cierra la app	Back regresa a la anterior	`DonarNavegacionUiTest.donarDesdeBarraInferiorYBackRegresaAInicioSinDestinosDeFiltros` (en el teléfono físico); M-RNF04	Pasan	Cumplido
RNF-05	Android 10 (API 29) o superior	Instala y corre sin fallas	`minSdk = 26` (Android 8), `targetSdk = 37`; probado en emulador Android 17 y en el teléfono físico Samsung SM-S947B con Android 16 (M-RNF05)	Instala y corre en Android 16 y 17	Parcialmente cumplido: no se probó en un equipo con Android 10 exacto
RNF-06	Cargando, vacío y error en toda pantalla con datos	Los tres estados se distinguen	`TengoAlgoParaDonarUiTest.loadingErrorReintentoYEmptyTienenRepresentacionSeparada`; `TengoAlgoParaDonarViewModelTest.vacioEsExitoYLaCargaYErrorSonIndependientesDeCampanas`; `UiState` común (TT-06)	Pasan 2 de 2	Cumplido
RNF-07	Confirmación de inscripción en menos de 2 s	10 inscripciones con red normal < 2 s	M-RNF07 en el teléfono contra el servidor desplegado	El servidor resuelve la inscripción en 25.9 ms; ida y vuelta por el túnel: promedio 169 ms, máximo 240 ms; la confirmación aparece en ~0.2 s	Cumplido

3.3 Requisitos de seguridad (rúbrica, parte 2)

ID	Control	Criterio	Prueba o evidencia	Resultado	Estado
SEG-01	Sesión e identidad robustas	Sin token, token alterado, `alg: none`, otro secreto o vencido → 401; refresh rotado y de un solo uso	`test_identidad.py::test_sin_token_es_401_y_dice_como_autenticarse`, `::test_contenido_alterado_rompe_la_firma`, `::test_alg_none_se_rechaza`, `::test_firmado_con_otro_secreto_se_rechaza`, `::test_token_vencido`, `::test_reusar_un_refresh_token_cierra_toda_la_sesion`; `smoke.sh` 4, 12, 13, 26-30	Pasan	Cumplido
SEG-02	Secretos no en claro	Contraseñas con Argon2id; códigos de recuperación como HMAC; token en el teléfono cifrado	`::test_la_contrasena_se_guarda_como_hash_argon2id`, `test_recuperacion.py::test_el_codigo_no_se_guarda_en_claro`	Pasan	Cumplido
SEG-03	Nadie accede a lo ajeno (IDOR/BOLA)	Otra familia no ve ni borra lo ajeno (404)	`test_autorizacion.py::test_bola_no_se_ven_ni_se_borran_acompanantes_ajenos`, `::test_bola_testimonio_sobre_asistencia_ajena`, `test_fotos.py::test_la_foto_de_perfil_no_la_ve_otra_familia`; `smoke.sh` 18-19	Pasan	Cumplido
SEG-04	Acciones críticas con privilegios y validación	Cada función de admin pide su permiso exacto; el cuerpo no puede subir permisos	`test_autorizacion.py::test_funciones_de_admin_piden_permiso` (6), `::test_mass_assignment_campos_extra_se_rechazan`, `test_politicas.py::test_las_funciones_de_admin_piden_su_permiso_y_solo_ese`, `::test_lo_que_no_tiene_regla_se_niega`	Pasan	Cumplido
SEG-05	Consultas parametrizadas y validación	SQLi en filtros, ids y cuerpos sin efecto; caracteres de control y topes	`test_entradas.py` (23); `test_minimo_privilegio.py` (10); `smoke.sh` 20-21	Pasan	Cumplido

ID	Control	Criterio	Prueba o evidencia	Resultado	Estado
SEG-06	Rate limit y bloqueo temporal	Inicio de sesión, registro y global con límite; 5 fallos bloquean el correo 15 min	`test_identidad.py::test_fuerza_bruta_bloquea_el_correo_aunque_cambie_de_ip` , `::test_limite_por_ip_del_inicio_de_sesion` , `test_seguridad_http.py::test_rate_limit_en_un_flujo_publico` , `::test_limite_global_por_ip` ; `smoke.sh` 35	Pasan	Cumplido
SEG-07	Tráfico cifrado y cabeceras de seguridad	HTTPS (TLS 1.2/1.3) en el camino público; HSTS, nosniff y CSP en cada respuesta	`test_seguridad_http.py::test_encabezados_de_seguridad_en_todas_las_respuestas` ; `smoke.sh` 22-24; `res/xml/seguridad_red.xml` (sin HTTP en claro); OWASP ZAP	Pasan	Cumplido
SEG-08	DAST con OWASP ZAP	Sin alertas altas ni medias, sin y con sesión	`backend/seguridad/zap/reporte-zap.*`	0 altas, 0 medias, 0 bajas, 1 informativa	Cumplido

3.4 Historias de usuario

Cada historia se demuestra con las pruebas del requisito que la origina.

HU	Requisitos	Estado
HU-01 Iniciar sesión y ver mis actividades e impacto	RF-11, RF-18, RF-23, RF-24	Cumplido
HU-02 Panel de administración	RF-24, SEG-04; CRUD de TT-12 (M-HU02)	Cumplido
HU-03 Detalle completo de una actividad	RF-04, RF-05	Cumplido
HU-04 Menú rápido en el encabezado	M-HU04	Cumplido
HU-05 Apartar artículos	RF-21	Cumplido
HU-06 Centros de donación con teléfono y mapa	RF-08, RF-10 (M-HU06)	Cumplido
HU-07 Aviso si se ocuparon los lugares mientras me inscribo	RF-05 (`sin_lugares` → pantalla P-08)	Cumplido
HU-08 Agregar al calendario	RF-07 (M-07)	Cumplido
HU-09 Cancelar hasta 12 h antes	RF-19	Cumplido
HU-10 Favoritos en mi perfil	RF-17, RF-27	Cumplido
HU-11 Testimonio con revisión	RF-12	Cumplido
HU-12 Encuestas con selección única, progreso y validación	RF-13 (`EncuestaViewModelTest.noPermiteAvanzarSinRespuesta`)	Cumplido
HU-13 Recordatorio 24 h antes	RF-16	Cumplido
HU-14 Solicitar la eliminación de mis datos	RF-15	Cumplido

3.5 Niveles de prueba

Nivel	Qué se prueba	Herramienta	Evidencia
Unitarias (JVM)	Reglas de avisos, niveles, fechas, cercanía, coordenadas, encuestas, caché sin conexión	JUnit, ViewModel con repositorio falso	`docs/evidencia/pruebas-app.txt` (60)
Interfaz (instrumentadas)	Estados cargando/vacío/error, filtros y Atrás en Compose	Compose UI Test en el teléfono físico	`docs/evidencia/pruebas-instrumentadas.txt` (4 de 4)
Integración del servidor	Cada regla contra PostgreSQL, Redis y RustFS reales; políticas Oso directas	pytest en Docker	`docs/evidencia/pytest-servidor.txt` (182)
Contrato	La API levantada responde lo que promete, incluidos los rechazos	`backend/smoke.sh` (bash + curl)	`docs/evidencia/smoke.txt` (35)
Concurrencia	8 familias por los mismos lugares a la vez	pytest con hilos y `Barrier`	`test_toctou_varias_familias_a_la_vez_no_sobrepasan_el_cupo`
Seguridad dinámica (DAST)	SQLi, XSS, inyección, cabeceras, fugas, sin y con sesión	OWASP ZAP 2.17	`backend/seguridad/zap/`
Sistema (extremo a extremo)	Flujos completos con el APK de release firmado contra el servidor desplegado	Teléfono físico	Guion M-xx (abajo) y video de respaldo

3.6 Guion de pruebas manuales en el teléfono (M-xx)

APK de release firmado, contra el servidor desplegado en Azure por el túnel HTTPS.

Corrida del 22 de octubre de 2026: teléfono físico Samsung SM-S947B (Android 16), con el APK 3.1 de entrega (SHA-256 `9cd0859e…`) instalado ese día, la sesión de la Familia Rodríguez y el servidor de Azure. La evidencia (capturas) está en `docs/evidencia/manual/`; se omitieron las que mostraban números telefónicos de los centros.

ID	Pasos	Resultado esperado	Resultado
M-01	Abrir la app sin cuenta → Inicio → "¿Cómo quieres ayudar hoy?" → Directorio → una categoría → una asociación	Se llega a una ficha sin buscar	Pasa (2026-10-22, teléfono) con la sesión de la Familia Rodríguez: Directorio → Comedores → ficha de «Comedor Apadrina un Niño» con necesidades, dirección y cómo ayudar, sin buscar. Sin cuenta, en el emulador (Android 17), también se llega a la ficha de un comedor desde Directorio → Comedores
M-02	Inicio → mapa → "Buscar cerca de: Apodaca"; luego mantener el dedo sobre otro punto	Sale "Lo más cerca de Apodaca" con 3 lugares y su distancia; el punto tocado cambia la lista. La app no pide permiso de ubicación	Pasa (2026-10-22, teléfono): «Apodaca» → «Lo más cerca de Apodaca» con Materno Infantil (proyecto, 10 km), Regalando Estrellas (actividad, 10 km) y Escucha Corazón (proyecto, 12 km); mantener el dedo en el mapa cambió la lista (1.6, 2.8 y 4.0 km). El manifiesto no declara permisos de ubicación (`dumpsys package`)
M-03	Abrir la ficha de 3 asociaciones	Qué hace, a quién ayuda, qué necesita, dirección y contacto	Pasa (2026-10-22, teléfono): tres fichas del Directorio (centros) con información, necesidades, cómo ayudar, dirección, WhatsApp, llamada y «Cómo llegar»
M-04	Abrir una actividad	Fecha, horario, lugar, qué se hará, edad mínima y lugares	Pasa (2026-10-22, teléfono): «Preparar despensas de fin de mes» con fecha, horario, lugar, punto de encuentro, capacidad y lugares tomados (13 / 20), qué haremos, recomendaciones y contacto. Esa actividad no tiene edad mínima; la regla se prueba en `test_edad_minima_se_revisa_en_el_servidor`

ID	Pasos	Resultado esperado	Resultado
M-06	Inscribirse con 2 acompañantes (uno menor, con consentimiento) → entrar como admin → Actividades → ícono "Quiénes van"	Aparece la familia con sus integrantes y "con menores"	Pasa (2026-10-20): la familia aparece con Sofía (9) y "con menores", vista como familia y como admin
M-07	En una actividad inscrita, "Agregar al calendario"	El calendario abre el evento con título, hora y lugar	Pasa (2026-10-20)
M-08	En una ficha: llamar, WhatsApp, correo	Cada botón abre la app correcta con el dato puesto	Pasa (2026-10-20): WhatsApp abre la conversación con el número
M-09	Proyectos y Donar	Se listan los vigentes con su detalle	Pasa (2026-10-22, teléfono): Proyectos (8 activos, 0 anteriores) y Donar (campañas con su avance)
M-10	Donar → una campaña → "¿Cómo donar?"	Qué llevar, dónde y horarios; ninguna pantalla de pago	Pasa con observaciones (2026-10-22, teléfono): las campañas muestran su meta y opciones para aportar (Destellos de Luz: tres opciones con precio informativo) y «Quiero ayudar» abre el marcador del teléfono; el qué llevar, dónde y horarios está en «Tengo algo para donar» y en el Directorio. Ninguna pantalla de pago. Hallazgo 1 (§3.7)
M-15	Perfil → Ajustes → Aviso de privacidad → "Solicitar eliminación" → folio. Entrar como admin → Perfil → "Solicitudes de eliminación" → Eliminar	Folio ELIM-xxxx; tras atenderla, esa cuenta ya no puede entrar	Pasa (2026-10-20): folio ELIM-0001; atendida, el inicio de sesión de esa cuenta responde 401
M-16	Inscribirse a una actividad de mañana; admin → Perfil → "Avisos con la app cerrada (en 20 s)"; cerrar la app	Llega el recordatorio como notificación	No ejecutada: pide la cuenta de administración (botón de avisos en 20 s). Evidencia sustituta: `AvisosTest` (3 pruebas) y M-22 (aviso del servidor con la app cerrada, 2026-10-20)
M-17	Marcar una asociación como favorita; la administración publica una actividad suya	Llega el aviso de lo nuevo	No ejecutada: pide la cuenta de administración. Evidencia sustituta: `AvisosTest` (2 pruebas) y M-22
M-18	Sin cuenta, abrir una actividad → "Unirme" → crear cuenta	Al terminar regresa a la misma actividad	Pasa (2026-10-20)
M-20	Donar → filtros por categoría y urgentes	Solo se ve lo que cumple	Pasa (2026-10-22, emulador Android 17, APK 3.2): en Donar se ven las categorías y «Filtros»; Alimentos deja «Suma a su Mesa», Ropa dice que no hay campañas de ropa y la hoja de filtros ofrece categoría y «Solo las que cierran esta semana». Con el APK 3.1 en el teléfono los filtros de campañas estaban ocultos (Hallazgo 2); «Tengo algo para donar» filtraba bien (Todos: 5 centros, Ropa: 4, Juguetes: 2)
M-22	Admin → "Enviar aviso a las familias" (urgencia de Monterrey) → app cerrada en otra cuenta de Monterrey	Llega la notificación	Pasa (2026-10-20) tras activar "Urgencias de tu ciudad" en Ajustes: las urgencias son opcionales (vienen apagadas) y al teléfono solo llegan de 8:00 a 21:00; fuera de ese horario quedan en la bandeja
M-26	Cambiar de Monterrey a Hermosillo	No aparece nada de la otra ciudad	Pasa (2026-10-20)
M-27	Marcar y desmarcar el corazón	Se refleja en "Mis favoritos"	Pasa (2026-10-22, teléfono): al marcar «Preparar despensas de fin de mes» aparece en «Mis favoritos» y al quitarla desaparece

ID	Pasos	Resultado esperado	Resultado
M-OFF	Abrir Actividades y Proyectos con red → modo avión → cerrar y abrir la app → abrir una ficha	Franja "Sin conexión · estás viendo lo guardado el..."; listas y fichas visibles; el cupo dice "Lugares no disponibles sin conexión"	Pasa (2026-10-20), con la API detenida 31 s en la VM (14:59:27 a 14:59:58 UTC; el túnel respondía 502): tras cerrar y abrir la app, Actividades y Proyectos salen de lo guardado con la franja ("guardado el 20 de octubre, 08:59" y "08:56": cada lista dice cuándo se guardó) y el cupo dice "Lugares no disponibles sin conexión". Con la API de vuelta, el cupo en vivo regresa (12/20). Capturas en `docs/evidencia/m-off-*.png`. Abrir la ficha sin conexión: por repetir en la demostración con modo avión
M-RNF01	`adb shell am start -W mx.tec.familiasquesuman/.MainActivity` 10 veces (arranque en frío) y medir la carga del catálogo	Promedio < 1.5 s	Pasa (2026-10-20): TotalTime promedio 117 ms, máximo 148 ms; catálogo visible en ~0.9 s
M-RNF03	Rotar a mitad de crear cuenta y de un testimonio	No se pierde lo escrito	Pasa (2026-10-22, emulador Android 17): en «Crear cuenta» se escribió nombre y correo, la pantalla se giró a horizontal y de regreso, y los dos textos siguieron ahí. El testimonio no se probó girando
M-RNF04	Recorrer Inicio → Actividad → Unirme → Atrás ×3	Regresa paso a paso, sin cerrar la app	Pasa (2026-10-20)
M-RNF05	Instalar el APK en el teléfono físico	Instala y abre sin fallas (versión de Android anotada)	Pasa (2026-10-20): Samsung SM-S947B, Android 16 (API 36)
M-RNF07	10 inscripciones/modificaciones con red normal	Confirmación < 2 s	Pasa (2026-10-20): ~0.2 s (servidor 25.9 ms; túnel promedio 169 ms, máximo 240 ms)
M-HU02	Admin: crear, editar, duplicar y borrar una actividad	Cada cambio se ve en la lista	Pasa (2026-10-20) duplicar y borrar; crear y editar por repetir en la demostración
M-HU04	Tocar el ícono de perfil del encabezado	Abre perfil, ajustes y notificaciones	Pasa (2026-10-22, teléfono): el ícono de perfil abre Mi perfil, Mis actividades, Notificaciones, Ajustes y Cerrar sesión
M-HU06	Directorio → un centro	Teléfono, dirección y mapa	Pasa (2026-10-22, teléfono): ficha de un centro con teléfono, dirección y «Cómo llegar» (mapa)
M-MAPA	Inicio → "Mapa de Monterrey": mover, acercar, tocar un puntero, "Agrandar" y "Cerrar"; "Ocultar" y "Ver mapa"	Calles de OpenStreetMap con los punteros de colores; el mini menú abre la ficha; a pantalla completa y de regreso	Pasa (2026-10-20)
M-BUSCAR	Buscar en Actividades ("bernabe") y en Donar ("tapitas")	Solo quedan las que coinciden, sin importar acentos ni mayúsculas	Pasa (2026-10-20)

Lo marcado "Pendiente" queda para correrlo en la demostración con el mismo APK.

3.7 Hallazgos de las pruebas del 22 de octubre

Los encontramos al correr las pruebas pendientes con el APK 3.1 en el teléfono. Se corrigieron en el **APK 3.2** (`versionCode 5`, 66 pruebas unitarias en verde) y los arreglos se comprobaron en el emulador (Android 17); las demás pruebas de la corrida se hicieron con el 3.1, que solo difiere en estos tres cambios.

#	Hallazgo	Causa	Efecto en la matriz	Corrección en 3.2
1	Al abrir el detalle de una campaña sin asociación, la app mostraba por error «Sin conexión · estás viendo lo guardado…»	El detalle pedía además `v1/asociaciones/` con el id vacío; el servidor lo respondía 307 hacia `http://` y la app, que prohíbe HTTP en claro, lo tomaba por falta de servidor	Cosmético: los datos sí llegaban (nota en M-10)	No se pide la asociación si el id viene vacío (`DetalleCampanaViewModel`); el detalle ya no muestra la franja
2	Los filtros de campañas (categoría y «Urgentes») no se veían	`MostrarFiltrosEnLista = false` en `CampanasScreen.kt` (la web no los tiene)	RF-20 estaba «Parcialmente cumplido»	Constante en `true`; M-20 pasa en 3.2
3	El texto decía «Cerca de el punto que elegiste»	Faltaba la contracción	Ninguno	Ahora dice «Cerca de un punto que elegiste»

4. Evidencia de los controles de seguridad

Cada punto de la rúbrica (parte 2) con el control que lo cumple, dónde está en el código y cómo se demuestra. El detalle técnico completo, con amenazas y matrices OWASP, está en la guía del backend: `docs/guia-backend.md` §4, §7 y §8.

Demostración en vivo (2 min): `bash backend/smoke.sh https://<túnel>`. Recorre los 35 casos, incluidos los rechazos (SQLi, token alterado, otra familia, admin, fuerza bruta), contra el servidor desplegado. Salida guardada en `docs/evidencia/smoke.txt`.

4.1 Controles en la API

Lo que pide la rúbrica	Control implementado	Dónde	Cómo se demuestra
Sesiones e identidad robustas; secretos nunca en claro	JWT HS256 de 15 min con `iss`, `aud`, `exp`, `iat`, `jti` obligatorios; refresh token de 30 días rotado y de un solo uso (reusarlo cierra toda la sesión); cerrar sesión revoca en el servidor (Redis); contraseñas con **Argon2id**; código de recuperación guardado como HMAC, 15 min, 5 intentos; en el teléfono los tokens van cifrados con **AES-256-GCM** del Android Keystore	`identidad.py`, `routers/sesion.py`, `ServicioSesion.kt`	SEG-01, SEG-02; `smoke.sh` 4-13, 26-32
Cada rol ve y hace solo lo suyo (IDOR/BOLA)	ABAC con Oso: cada regla en `politicas.polar` ("negar por omisión"); lo ajeno responde **404** (no revela que existe); permisos separados por función (`administrar:catalogo`, `moderar:contenido`, `registrar:asistencias`, `atender:privacidad`)	`politicas.polar`, `politicas.py`, `routers/*`	SEG-03, SEG-04; `smoke.sh` 14-19
Acciones que modifican o borran con validación y privilegios	Cada ruta de `/v1/admin` exige su permiso; el cuerpo no puede traer permisos ni rol (mass assignment → 422); cambiar permisos invalida los tokens viejos; borrar con historial responde 409; cada acción sensible queda en la tabla `auditoria` (con huella HMAC de la IP); en la app, confirmación antes de borrar	`routers/admin.py`, `bitacora.py`	`test_autorizacion.py`, `test_politicas.py`
Consultas parametrizadas y validación estricta	SQLAlchemy (nunca SQL armado con texto); Pydantic con `extra="forbid"`, topes de longitud, rangos, rechazo de caracteres de control, enlaces solo `https:` / `tel:` / `mailto:`; la API entra a PostgreSQL con un usuario sin DDL	`esquemas.py`, `modelos.py`, `afterMigrate.sql`	SEG-05; `test_entradas.py` (23), `test_minimo_privilegio.py` (10); `smoke.sh` 20-21; ZAP reglas 40018-40022 sin hallazgos
Rate limiting y bloqueo temporal en inicio de sesión y registro	Iniciar sesión: 10/min y 60/h por IP; registro: 10/h por IP; recuperar: 5/h; límite global por IP; 5 contraseñas equivocadas bloquean ese correo 15 min venga de la IP que venga; contadores en Redis con ventana deslizante	`limites.py`, `identidad.py`	SEG-06; `smoke.sh` 35

Lo que pide la rúbrica	Control implementado	Dónde	Cómo se demuestra
Tráfico cifrado y cabeceras de seguridad	Teléfono ↔ Cloudflare con TLS 1.2/1.3 (la app rechaza versiones viejas y HTTP en claro: `seguridad_red.xml`, `RESTRICTED_TLS`); cabeceras en cada respuesta: `Strict-Transport-Security`, `X-Content-Type-Options: nosniff`, `Content-Security-Policy: default-src 'none'`, `X-Frame-Options: DENY`, `Referrer-Policy`, `Cache-Control: no-store`	`seguridad.py`, `res/xml/seguridad_red.xml`	SEG-07; `smoke.sh` 22-24; `curl -I`

4.2 Infraestructura y despliegue seguro

Lo que pide la rúbrica	Cómo quedó
Contenedores con aislamiento y secretos por variables de entorno	Todo en Docker Compose. Contenedores sin capacidades de Linux (`cap_drop: ALL`), `no-new-privileges`, límites de memoria y procesos, la API con sistema de archivos de solo lectura. Tres redes: `borde` (túnel y API), `datos` (interna, sin internet: base, Redis, almacén) y `monitoreo` (interna). La API recibe solo sus variables (no tiene la contraseña de dueño de la base). Secretos en `backend/.env`, fuera de Git; con `ENTORNO=produccion` la API **se niega a arrancar** si encuentra un secreto de ejemplo
Expuesto por un túnel y consumido por la app	`cloudflared` sale hacia Cloudflare (sin abrir puertos). La API solo cree el encabezado `CF-Connecting-IP` si viene de la IP fija del túnel. La app de release habla solo HTTPS con esa dirección
Servidor endurecido	VM de Azure con dos firewalls en "negar por omisión", como el firewall *stateful* de la sesión 24: el grupo de seguridad de red de Azure y `ufw` en la VM. Solo entra SSH (22) con llave, sin contraseñas; ningún puerto de la API, la base ni Grafana queda expuesto. Para enseñar Grafana en la presentación se abre un segundo túnel de salida, solo a Grafana y con su usuario y contraseña, que se quita al terminar. Ver `06-manual-instalacion.md` §6.3

4.3 Validación de seguridad

Caso	Qué responde la API	Evidencia
Inyección SQL en un filtro y en un id	422, sin consultar la base	`smoke.sh` 20-21, `test_entradas.py::test_sqli_en_filtros_de_busqueda`
Token alterado (sin volver a firmar)	401	`smoke.sh` 12, `test_identidad.py::test_contenido_alterado_rompe_la_firma`
Token vencido	401 `token_expirado`	`test_identidad.py::test_token_vencido`
`alg: none` u otro algoritmo	401	`::test_alg_none_se_rechaza`, `::test_otro_algoritmo_con_el_mismo_secreto_se_rechaza`
Refresh token reusado	401 y se cierra toda la sesión	`smoke.sh` 27-28

Caso	Qué responde la API	Evidencia
Consultar o borrar datos de otra familia	404	`smoke.sh` 18, `test_autorizacion.py::test_bola_no_se_ven_ni_se_borran_acompanantes_ajenos`
Familia entrando a funciones de admin	403	`smoke.sh` 14
Registrarse como admin (campo extra)	422	`smoke.sh` 7
Fuerza bruta contra un correo	429 tras 5 intentos, aunque la contraseña sea buena	`smoke.sh` 35
Exceso de peticiones	429 con `Retry-After`	`test_seguridad_http.py::test_limite_global_por_ip`
Foto con HTML disfrazado, políglota o bomba de descompresión	422 / se limpia	`test_fotos.py`

DAST con OWASP ZAP 2.17 (detalle en la guía §13). Dos pasadas: sin sesión y con el token de una cuenta de escaneo sin datos reales.

Riesgo	Alertas
Alto	0
Medio	0
Bajo	0
Informativo	1 (*User Agent Fuzzer*)

La alerta informativa no es una vulnerabilidad. ZAP compara respuestas con distintos `User-Agent`; la API no lo lee, y lo que cambia es el `solicitud` único de cada respuesta de error. Reporte: `backend/seguridad/zap/reporte-zap.html`.

5. Manual de usuario

Para las familias que usan la app y para el equipo de Familias que Suman. Las capturas están en `docs/entrega-3/img/` y se tomaron del APK de entrega en un teléfono físico.

5.1 Lo primero

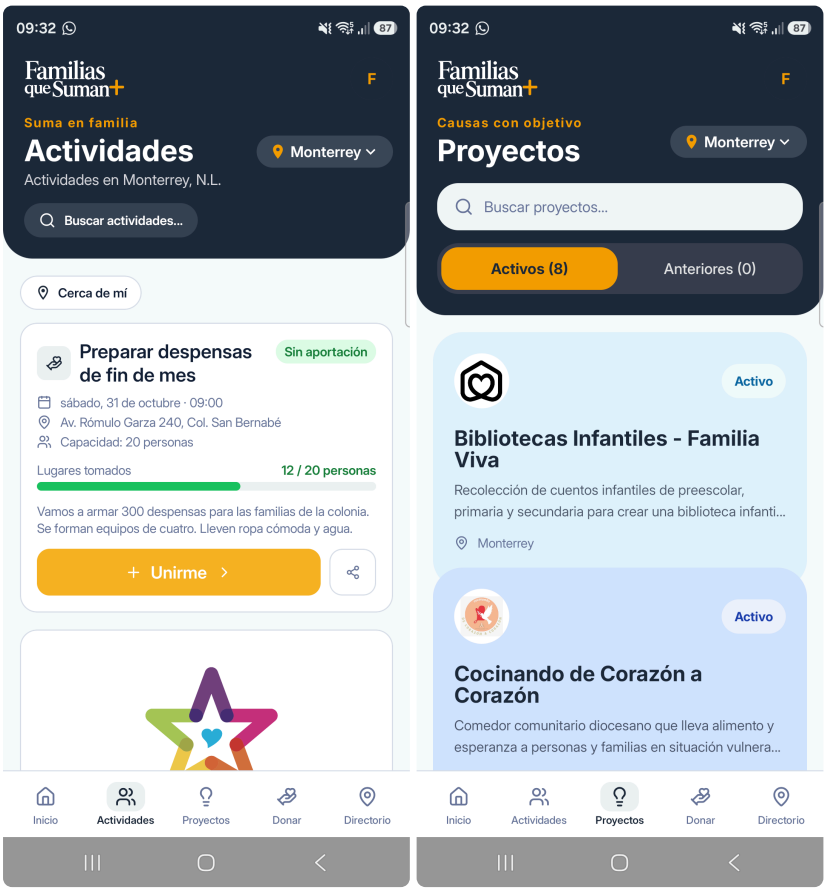
1. Instala la app (ver el manual de instalación, §6.1) y ábrela.
2. Elige tu ciudad: **Monterrey** o **Hermosillo**. Puedes cambiarla después desde el encabezado o en Perfil → Ajustes.
3. Si la app te pide permiso para mandarte **notificaciones**, acéptalo para recibir recordatorios y avisos. Puedes apagarlos cuando quieras en Ajustes.

No necesitas cuenta para explorar. La app te la pide solo cuando quieras inscribirte, guardar favoritos o ver tu perfil.

5.2 La barra de abajo

Pestaña	Qué encuentras
Inicio	"¿Cómo quieres ayudar hoy?", tus próximas actividades, testimonios de otras familias
Actividades	Voluntariados de tu ciudad, con fecha, lugar, edad mínima y lugares disponibles
Proyectos	Proyectos de Familias que Suman y cómo apoyarlos
Donar	Campañas de donación con lo que se necesita, cuánto falta y dónde entregarlo
Directorio	Asociaciones y centros de donación verificados, por categoría

El ícono de tu perfil, arriba a la derecha, abre Mi perfil, Mis actividades, Notificaciones y Ajustes.



5.3 Encontrar una causa y contactarla

1. En **Directorio**, toca una categoría (por ejemplo, *Alimentación*) y luego una asociación.
2. La ficha dice qué hace, a quién ayuda, qué necesita y dónde está.
3. Toca **Llamar**, **WhatsApp** o **Correo** (en proyectos y centros, también **Instagram**): se abre la app correspondiente con el dato ya puesto.



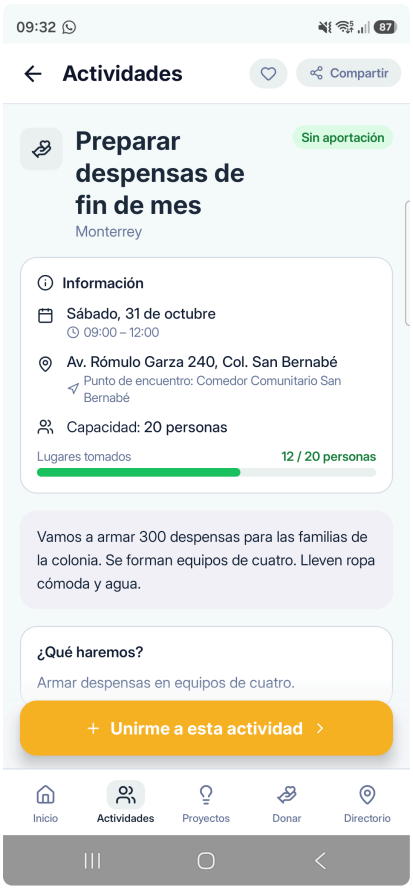
El mapa (en Inicio) muestra las calles de tu ciudad con los puntos de actividades (morado), proyectos (azul), donaciones (verde) y centros del Directorio (menta). Filtra por tipo con los botones de arriba, toca un punto para ver su resumen y entrar a su ficha, y usa **Agrandar** para verlo a pantalla completa (**Cerrar** para volver).

Buscar: en Actividades y en Donar toca **Buscar…** en el encabezado y escribe una palabra (la actividad, la asociación o la colonia); no importan acentos ni mayúsculas. La ✕ cierra la búsqueda. Proyectos y Directorio tienen su buscador siempre visible.

Buscar cerca de (en el mapa del Inicio): escribe tu municipio, tu colonia o una calle (por ejemplo "Apodaca") y toca **Buscar**, o mantén el dedo sobre un punto del mapa. El mapa va ahí y abajo salen los tres lugares más cercanos con su distancia ("a 2.3 km"). La app no pide tu ubicación. La ✕ del chip "Cerca de…" lo quita.

5.4 Inscribirse a una actividad

1. En **Actividades**, abre una tarjeta para ver el detalle y toca **Unirme a esta actividad**.
2. Si no tienes cuenta, toca **Crear cuenta**. Escribe tu correo, una contraseña (una frase es más segura que una palabra) y el nombre de tu familia, y acepta el aviso de privacidad. Al terminar regresas a la misma actividad.
3. Elige **quiénes van**: tú y los acompañantes que registres (nombre y fecha de nacimiento). Si van menores de edad, marca la casilla de consentimiento como madre, padre o tutor.
4. Toca **Confirmar**. Si otra familia ganó los últimos lugares mientras tanto, la app te avisa y te sugiere otras actividades.
5. En la confirmación puedes tocar **Agregar al calendario**: se abre tu calendario con la fecha, la hora y el lugar.

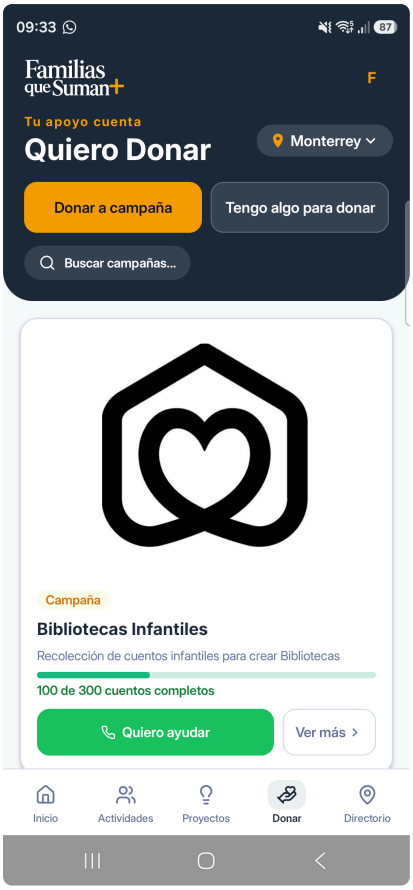


Un día antes recibirás un **recordatorio**, aunque no abras la app.

Modificar o cancelar: Perfil → **Mis actividades** → la actividad. Puedes cambiar quiénes van sin perder tus lugares, o **cancelar** hasta 12 horas antes; los lugares se liberan para otras familias.

5.5 Donar a una campaña

1. En **Donar**, usa los filtros (categoría o *Urgentes*) y abre una campaña.
2. Ves la meta, cuánto se ha juntado y qué falta.
3. Toca **Donar** en un artículo, elige cuántos te comprometes a llevar y confirma. Se resta de lo que falta para todas las familias.
4. **¿Cómo donar?** dice qué llevar, dónde entregarlo y en qué horario.



La app no cobra nada ni pide datos de pago: solo registra tu compromiso.

5.6 Tu perfil

- **Tu impacto:** actividades realizadas, horas de servicio, campañas apoyadas y la gráfica por mes. Salen de las asistencias que registra la asociación.
- **Insignias:** suben de nivel con tu participación.
- **Mis favoritos:** toca el corazón en una asociación, actividad o campaña para guardarla. Te avisamos cuando publique algo nuevo o cuando una campaña esté por cerrar.
- **Mi familia:** agrega o quita acompañantes para no escribirlos cada vez.
- **Foto de perfil:** elige una de la galería o tómala con la cámara. Antes de subirla, la app la reduce y le quita la ubicación y otros metadatos.

5.7 Contar tu experiencia

Después de una actividad a la que asististe:

1. Perfil → **Mis actividades** → una actividad pasada → **Compartir testimonio**.
2. Escribe tu experiencia y agrega una foto (galería o cámara).
3. Envíalo. **Queda en revisión:** solo tú lo ves hasta que Familias que Suman lo aprueba. Si lo editas, vuelve a revisión. Puedes borrarlo cuando quieras.

También puedes contestar la **encuesta** antes de la actividad y otra al terminar. Son preguntas de una sola opción; la app no te deja avanzar sin contestar.

5.8 Avisos y notificaciones

En Perfil → **Ajustes** decides qué recibir:

- recordatorio un día antes de tus actividades;
- novedades de tus favoritos;
- urgencias de tu ciudad (por ejemplo, "Se necesitan 5 voluntarios").

Los avisos se revisan cada 15 minutos aunque la app esté cerrada. Android puede retrasarlos un poco para ahorrar batería. Todos quedan en Perfil → **Notificaciones**.

5.9 Sin internet

Lo que ya abriste se queda guardado en el teléfono. Sin conexión verás arriba **"Sin conexión · estás viendo lo guardado el ..."**, y podrás consultar las actividades, proyectos, campañas y fichas guardadas. Los lugares disponibles no se muestran, porque sin internet podrían estar viejos. Inscribirte o donar necesita conexión.

5.10 Si olvidaste tu contraseña

1. En **Iniciar sesión**, toca **¿Olvidaste tu contraseña?** y escribe tu correo.
2. Te llega un **código de 6 dígitos**: sirve 15 minutos y una sola vez.
3. Escríbelo con tu contraseña nueva. Las sesiones abiertas en otros teléfonos se cierran.

Por seguridad, la app responde igual exista o no una cuenta con ese correo.

5.11 Tus datos

Perfil → Ajustes → **Aviso de privacidad** explica en lenguaje claro qué datos guardamos, para qué y por cuánto tiempo.

- **Corregir tus datos:** desde Perfil.
- **Eliminarlos:** toca **Solicitar eliminación de mis datos**. Recibes un folio (por ejemplo, ELIM-0007). En un máximo de 20 días se atiende y, si procede, en los 15 siguientes se borran tu cuenta, tus acompañantes, inscripciones, encuestas, testimonios y fotos.

5.12 Para el equipo de Familias que Suman (administración)

Las cuentas con permisos ven funciones extra. Los permisos los asigna quien administra el servidor (§6.2.5); nadie se los puede dar desde la app.

Tarea	Dónde
Crear una actividad	Actividades → botón **+** (fecha como "sábado, 3 de octubre", horario "09:00 – 11:30", cupo, edad mínima, ubicación en el mapa)
Editar, duplicar o borrar	Íconos debajo de cada tarjeta (lápiz, copiar, bote)
Ver quiénes van	Ícono de persona debajo de cada actividad: familias inscritas, integrantes, edades y si van menores. Solo nombres y edades: sin correos ni teléfonos
Proyectos, campañas, centros y asociaciones	Mismo esquema en cada pestaña
Revisar testimonios	Perfil → **Testimonios** → aprobar o rechazar
Ver sugerencias	Perfil → **Sugerencias recibidas**
Enviar un aviso	Perfil → **Enviar aviso a las familias** (urgencia de una ciudad o general)
Ver respuestas de encuestas	Perfil → **Respuestas de encuestas**
Atender solicitudes de eliminación	Perfil → **Solicitudes de eliminación de datos** → **Eliminar los datos** (pide confirmación; no se puede deshacer)
Probar las notificaciones en una demostración	Perfil → **Probar notificaciones** (solo la administración lo ve)

Cada acción de administración la vuelve a revisar el servidor y queda en la auditoría.

6. Manual de instalación

Tres formas de poner el sistema a funcionar, de la más simple a la completa:

Quiero…	Sección
Solo usar la app contra el servidor que ya está en internet	§6.1
Levantar todo en mi computadora (app en el emulador, API en Docker)	§6.2
Publicar el servidor en internet (Azure for Students, sin tarjeta)	§6.3

Repositorio: https://github.com/albertolopezb/familias-que-suman (tag `entrega-final`).

6.1 Instalar la app en un teléfono

Requisitos: teléfono Android 8.0 o superior con internet.

1. Descarga `familias-que-suman-v3.2.apk` (enlace en la sección 10 del documento).
2. Ábrelo en el teléfono. La primera vez, Android pide permitir **instalar apps de origen desconocido** para el navegador o el administrador de archivos: acéptalo solo para esta instalación.
3. Abre **Familias que Suman**, elige tu ciudad y listo.

Por cable, desde una computadora (depuración USB activada en *Opciones de desarrollador*):

```
adb install -r familias-que-suman-v3.2.apk
```

Comprobar que el APK es el original (firmado por el equipo):

```
apksigner verify --print-certs familias-que-suman-v3.2.apk
```

Debe decir `CN=Familias que Suman, OU=TC2007B` y la huella SHA-256 `88:c7:bb:77:…:87:0c`.

6.2 Todo en tu computadora

6.2.1 Requisitos

Programa	Versión	Para qué
Git	cualquiera	Clonar
Docker Desktop	4.x con Compose v2	El backend completo
Android Studio	2025.x o más reciente (trae el JDK 17+)	Compilar y correr la app
Espacio	~6 GB	Imágenes de Docker y Gradle

6.2.2 Backend

```
git clone https://github.com/albertolopezb/familias-que-suman.git
cd familias-que-suman/backend
docker compose up -d --build
```

La primera vez descarga las imágenes y construye la API (unos minutos). Después:

- Comprobar que está viva: abrir http://localhost:8000/v1/salud → `{"estado":"ok"}`.
- Documentación interactiva de la API (solo en desarrollo y desde tu máquina): http://localhost:8000/docs
- Correo de desarrollo (los códigos para recuperar la contraseña): http://localhost:8025
- Grafana: http://localhost:3000

No hace falta crear un `.env`: sin él se usan valores de desarrollo. Para cambiarlos, copia `backend/.env.example` a `backend/.env`.

Datos de prueba: se cargan solos (asociaciones, actividades, campañas y proyectos de Monterrey y Hermosillo). Cuentas de desarrollo: `ana.rodriguez@correo.com` (familia) y `admin@correo.com` (administración). Sus contraseñas están en `backend/db/seed/dev.sql`, solo para desarrollo.

Pruebas:

```
docker compose --profile pruebas run --rm --build pruebas
```

```
bash smoke.sh
```

```
bash seguridad/zap/escanear.sh
```

- La primera son las 191 pruebas del servidor.
- La segunda es la prueba de contrato de 35 casos contra la API levantada.
- La tercera es OWASP ZAP sin y con sesión.

6.2.3 App en el emulador

1. Android Studio → **File** → **Open** → la carpeta `familias-que-suman` (la raíz, no `app/`). Espera el *Gradle sync*.
2. En `local.properties` (se crea solo; no se sube a Git) agrega: `properties api.url=http://10.0.2.2:8000` `10.0.2.2` es tu computadora vista desde el emulador.
3. ▶ **Run** con un emulador (API 26+). En Android 17, acepta el permiso de *red local* al abrir: sin él, la app no llega a tu computadora.

Pruebas de la app:

```
./gradlew :app:testDebugUnitTest
```

```
./gradlew :app:connectedDebugAndroidTest
```

La primera son las 66 pruebas locales. La segunda son las pruebas de interfaz y necesitan un emulador o un teléfono conectado.

6.2.4 APK de entrega firmado

1. La llave de firma vive **fuera del repositorio**. Agrega a `local.properties`: `properties api.url.release=https://<dirección del servidor> # solo HTTPS firma.archivo=D\:/TEC/.llaves/familias-que-suman-release.jks firma.alias=familias-release firma.contrasena=<contraseña de la llave>`
2. Compila: `bash ./gradlew :app:assembleRelease` Queda en `app/build/outputs/apk/release/app-release.apk`. Sin la llave, el APK sale sin firmar. Cada actualización debe ir firmada con la **misma** llave: respáldala.

6.2.5 Dar permisos de administración

Nadie se hace admin desde la app. Quien administra el servidor lo da:

```
docker compose exec api python -m app.herramientas permisos <correo> todos
```

Con `ninguno` se quitan. Para un permiso suelto: `moderar:contenido`, `registrar:asistencias`, `administrar:catalogo` o `atender:privacidad`.

6.3 Servidor en internet: Azure for Students

Microsoft da **100 USD de crédito sin tarjeta** a estudiantes, verificando con el correo institucional. La VM de la demostración cuesta unos 37 USD al mes (cómputo, disco e IP), corre el mismo `docker compose` y no se duerme. Si se acaba el crédito, la suscripción se detiene: no hay cobros.

6.3.1 Crear la máquina (una vez)

1. Activar la suscripción en https://azure.microsoft.com/es-mx/free/students con el correo `@tec.mx`.
2. En https://portal.azure.com abrir **Cloud Shell** (ícono `>_`, modo Bash) y elegir la suscripción de estudiante. Si la cuenta también tiene la del Tec (*ITESM - LabVirtual*), esa no permite crear recursos: `bash az account set --subscription "Azure for Students"`
3. Ver en qué regiones deja crear recursos la suscripción. La de estudiante trae la política *Allowed resource deployment regions*; en octubre de 2026 eran `northcentralus`, `canadacentral`, `belgiumcentral`, `brazilsouth` y `norwayeast`, ninguna en México: `bash az policy assignment list --disable-scope-strict-match --query "[].parameters.listOfAllowedLocations.value" -o json`
4. Crear el grupo de recursos y la VM con Ubuntu 24.04, solo SSH y la llave **pública** (la privada se queda en tu computadora): `bash az group create --name familias-que-suman-rg --location mexicocentral` `bash az vm create --resource-group familias-que-suman-rg --name familias-que-suman --location northcentralus --image Canonical:ubuntu-24_04-lts:server:latest --size Standard_B2als_v2 --admin-username azureuser --ssh-key-values "<llave pública ssh-ed25519>" --public-ip-sku Standard --os-disk-size-gb 64 --storage-sku StandardSSD_LRS --nsg-rule SSH` Si responde *SkuNotAvailable* (sin capacidad), probar otro tamaño de 2 vCPU y 4 GB o más (`Standard_B2s_v2`, `Standard_B2as_v2`) u otra región permitida. La salida trae `publicIpAddress`.

El grupo de seguridad de red solo deja entrar SSH (22). No se abre ningún otro puerto: la API sale a internet por el túnel.

6.3.2 Desplegar (y redesplegar)

Desde la raíz del repositorio, en tu computadora:

```
bash backend/despliegue/desplegar.sh <IP pública> azureuser <ruta a la llave privada>
```

El script:

1. Instala Docker desde los paquetes de Ubuntu y deja `ufw` en "negar por omisión", con solo SSH.
2. Sube `backend/` tal como está en el último commit.
3. La primera vez genera en la VM un `.env` con **secretos al azar** y `ENTORNO=produccion` (la API no arranca con un secreto de ejemplo).
4. Levanta todo con el túnel.
5. Cambia las contraseñas de las cuentas de prueba por unas al azar y las guarda **en tu computadora**, en `D:/TEC/.llaves/cuentas-demo.txt`.
6. Imprime la dirección `https://….trycloudflare.com`.

Volver a correrlo actualiza el código y conserva los datos y los secretos. El mismo script sirve para Oracle Cloud Always Free (usuario `ubuntu`) o cualquier VM con Ubuntu 24.04.

6.3.3 Operación

Todo se hace por SSH (`ssh -i <llave> azureuser@<IP>`), en `~/familias/backend`:

Para	Comando
Ver el estado	`sudo docker compose ps`
Ver la dirección pública del túnel	`sudo docker compose logs tunel | grep trycloudflare`
Logs de la API	`sudo docker compose logs -f api`

Para	Comando
Grafana y el correo de desarrollo desde tu computadora	`ssh -i <llave> -L 3000:127.0.0.1:3000 -L 8025:127.0.0.1:8025 azureuser@<IP>` y abrir http://localhost:3000 y http://localhost:8025
Enseñar Grafana sin túnel SSH (solo para una presentación)	`sudo docker run -d --name tunel-grafana --restart unless-stopped --network familias-que-suman_local --read-only --memory 128m --security-opt no-new-privileges cloudflare/cloudflared:2026.10.0 tunnel --no-autoupdate --protocol http2 --url http://grafana:3000`; la dirección sale en `sudo docker logs tunel-grafana | grep trycloudflare`. Pide el usuario y la contraseña de Grafana. Al terminar: `sudo docker rm -f tunel-grafana`
Respaldo de la base	`sudo docker compose exec db pg_dump -U familias -d familias -Fc > respaldo-$(date +%F).dump`

Cuidar el crédito (en Cloud Shell):

Para	Comando
Apagar la VM (deja de cobrar el cómputo)	`az vm deallocate -g familias-que-suman-rg -n familias-que-suman`
Prenderla	`az vm start -g familias-que-suman-rg -n familias-que-suman`
Borrar todo al terminar el curso	`az group delete -n familias-que-suman-rg --yes`

La dirección de Quick Tunnel cambia si se reinicia el contenedor del túnel o la VM. Si pasa, hay que volver a compilar el APK con la nueva `api.url.release`. Con un dominio propio, el túnel con nombre (`--profile tunel-nombrado`, guía §10.3) da una dirección fija.

6.4 Problemas comunes

Síntoma	Qué hacer
`port is already allocated`	Otro programa usa el puerto: cambia `API_PORT` u otro puerto en `backend/.env`
La app en el emulador dice "sin conexión"	Android 17: acepta el permiso de red local, o `adb shell pm grant mx.tec.familiasquesuman android.permission.ACCESS_LOCAL_NETWORK`
El APK de entrega dice "sin conexión"	`api.url.release` apunta a un túnel viejo: revisa la dirección actual y vuelve a compilar
429 `demasiados_intentos` al entrar	5 contraseñas equivocadas: espera 15 minutos
Docker Desktop "unable to start"	Disco lleno: libera espacio
`SkuNotAvailable` o `RequestDisallowedByAzure` al crear la VM en Azure	Otro tamaño, o una región de las que permite la política de la suscripción (§6.3.1)
`AuthorizationFailed` al crear el grupo de recursos	Estás en la suscripción del Tec: `az account set --subscription "Azure for Students"`

Más casos: guía del backend §14.5.

7. Plan de implantación

Cómo poner el sistema en operación con Familias que Suman, de la entrega del reto a su uso real.

7.1 Versión entregada

Pieza	Versión
Repositorio	tag `entrega-final`
App Android	`versionName 3.2`, `versionCode 5`, firmada con la llave del equipo (SHA-256 `88:C7:BB:77:6B:BF:3C:49:3F:D3:38:CC:14:17:33:60:74:EB:65:52:BC:8E:88:45:EC:E6:AE:7C:E8:F2:87:0C`); Android 8.0+ (`minSdk 26`), `targetSdk 37`
API	FastAPI, Python 3.12, imagen construida del mismo tag
Esquema de la base	Flyway `V1` a `V9`
Servidor	VM de Microsoft Azure (Azure for Students), Standard_B2als_v2, Ubuntu 24.04, North Central US, con Docker Compose

7.2 Canal de distribución

Etapa	Canal	Por qué
Piloto (entrega del reto y primeras familias)	**APK firmado** descargable desde un enlace del equipo (Drive o la página de *Releases* de GitHub), instalado con "origen desconocido"	Sin costo ni revisión de tienda; permite probar con pocas familias
Operación	**Google Play**, con una cuenta de desarrollador **a nombre de Familias que Suman** (pago único de 25 USD), primero en *prueba interna* y luego en producción	Actualizaciones automáticas y confianza de las familias. La ficha de Play debe enlazar el mismo aviso de privacidad. Si la llave de firma pasa a Play App Signing, la huella nueva se agrega a `APP_HUELLAS_SHA256`

La llave de firma y su contraseña se entregan a la OSF por un canal privado (no por correo ni por el repositorio) y se guardan en dos lugares.

7.3 Configuración necesaria

Qué	Dónde	Quién
Secretos de producción (base, Redis, almacén, `JWT_SECRETO`, `HMAC_SECRETO`, Grafana) al azar y distintos	`backend/.env` en el servidor (lo genera `desplegar.sh`)	Equipo técnico
`ENTORNO=produccion`	`backend/.env`	`desplegar.sh`
Dirección pública HTTPS	Quick Tunnel (piloto) o túnel con nombre y dominio propio (operación)	Equipo técnico / OSF (dominio)
`api.url.release` de la app con esa dirección	`local.properties` al compilar	Equipo técnico

Qué	Dónde	Quién
Correo real para recuperar contraseñas	`SMTP_HOST`, `SMTP_PUERTO`, `SMTP_USUARIO`, `SMTP_CONTRASEÑA`, `SMTP_TLS=true`	OSF (cuenta de correo transaccional)
Cuentas de administración	`python -m app.herramientas permisos <correo> <permiso>`	Equipo técnico, a pedido de la OSF
Responsable, domicilio y correo del aviso de privacidad	`Responsable` en `AvisoPrivacidadScreen.kt`	OSF (razón social y domicilio completos)
App Links con dominio propio	`enlaces.dominio` en la app y `ENLACES_BASE` en el servidor	Equipo técnico

7.4 Procedimiento de despliegue

1. **Antes:** - Las 191 pruebas del servidor y las 66 de la app en verde. - ZAP sin altas ni medias. - Etiquetar el commit (`git tag vX.Y-…`).
2. **Respaldo** (si ya hay datos): `bash ssh … 'cd ~/familias/backend && sudo docker compose exec -T db pg_dump -U familias -d familias -Fc' > respaldo-AAAA-MM-DD.dump`
3. **Desplegar el servidor:** `bash backend/despliegue/desplegar.sh <IP> <usuario>`. Flyway aplica solo las migraciones nuevas; el `.env` y los volúmenes se conservan.
4. **Verificar:** `bash backend/smoke.sh https://<dirección>` (35 casos) y revisar en Grafana que no suban los 5xx ni los 401/403.
5. **Publicar la app:** compilar con la dirección final, subir el APK (o el AAB a Play) y avisar a las familias del piloto.
6. **Capacitación** al equipo de la OSF (1 sesión, con el §5.12 del manual): administrar el catálogo, revisar testimonios, enviar avisos, ver quiénes van y atender solicitudes de eliminación.
7. **Piloto de 2 semanas** con 5 a 10 familias y 2 actividades reales. Al terminar se revisan las encuestas y los incidentes antes de abrirlo a todas las familias.

7.5 Carga inicial de información

Familias que Suman no tiene una base de datos previa que migrar. Su información vive hoy en el sitio web (familiasquesuman.com) y en hojas de cálculo y mensajes del equipo.

Datos	Cómo se cargan
Esquema	Flyway lo crea solo al levantar (`backend/db/migrations`)
Ciudades (Monterrey, Hermosillo)	Migraciones
Asociaciones, proyectos, campañas, centros y actividades	El equipo de la OSF los captura desde la app con su cuenta de administración (§5.12). Para una carga grande, un script SQL con el formato de `backend/db/seed/dev.sql`, revisado y ejecutado por el equipo técnico
Fotos y logos	Se suben desde la administración; el servidor las re-codifica y les quita los metadatos

Datos	Cómo se cargan
Familias	No se importan: cada familia crea su cuenta y acepta el aviso de privacidad (consentimiento)
Datos de prueba	En producción **no** deben quedar las cuentas de prueba. En el piloto se conservan con contraseñas al azar (`desplegar.sh`) y se borran al abrirlo a todas las familias

7.6 Rollback (si la implantación falla)

Señal	Decisión
`smoke.sh` falla, `/v1/salud` no responde o los 5xx suben en Grafana después de desplegar	Regresar el servidor a la versión anterior
La app nueva truena o no puede entrar	Publicar la versión anterior

Servidor:

1. `git checkout <tag anterior>` y `bash backend/despliegue/desplegar.sh <IP> <usuario>`. Se reconstruye la API con el código anterior.
2. Si la versión nueva traía una **migración**, Flyway no deshace cambios. Se restaura el respaldo del paso 7.4-2: `bash sudo docker compose exec -T db pg_restore -U familias -d familias --clean < respaldo-AAAA-MM-DD.dump`
3. Verificar con `smoke.sh`.

Tiempo estimado: 15 minutos.

App: Android no deja instalar una versión con `versionCode` menor encima de una mayor. El rollback es publicar el código anterior con un `versionCode` **nuevo y mayor**, firmado con la misma llave (en Play, también se puede detener el lanzamiento escalonado).

Si el servidor no está disponible (se acaba el crédito de estudiante o la región se queda sin capacidad): el mismo `docker compose` corre en cualquier máquina con Docker. Se restaura el último respaldo y se publica con el túnel; la app solo necesita la nueva dirección.

7.7 Después de implantar

- **Respaldos:** `pg_dump` diario con cron en la VM; una copia semanal fuera del servidor.
- **Monitoreo:** alertas de Grafana (guía §11): fuerza bruta, picos de 403, entradas inválidas.
- **Privacidad:** atender las solicitudes de eliminación en el plazo legal (20 + 15 días) desde la app.
- **Actualizaciones:** dependencias cada mes (`uv lock --upgrade`, versiones de imágenes) con las pruebas y ZAP antes de desplegar.

8. Administración final del proyecto

Plan en Planner: **Reto TC2007B.402** (exportado el 15 de octubre de 2026 y actualizado para esta entrega). Captura del tablero final en la sección 10.

Nota sobre el registro. El tablero ya tenía los requerimientos, historias, tareas técnicas y la lista del documento final. El trabajo de backend, seguridad, despliegue en Azure y modo sin conexión se hizo sin darlo de alta tarea por tarea; el 22 de octubre se agregaron como tareas «(retroactivo)» con las fechas reales que muestra el historial de Git y se marcaron completadas ese día (Planner guarda como fecha de cierre el momento en que se marca, no la fecha de la tarea).

8.1 Backlog final y estado de los requerimientos

Tipo	Total	Terminados	Parciales	Fuera
Requerimientos funcionales (RF-01 a RF-29)	29	29	0	0
Requerimientos no funcionales (RNF-01 a RNF-07)	7	6 (RNF-01, 02, 03, 04, 06 y 07)	1: RNF-05 (no se probó en Android 10 exacto)	0
Historias de usuario (HU-01 a HU-14)	14	14	0	0
Tareas técnicas (TT-01 a TT-16)	16	16	0	0

El estado de cada uno, con su prueba, está en la matriz de trazabilidad (§3). RNF-01 y RNF-07 se midieron el 20 de octubre con el APK de entrega en un Samsung con Android 16, contra el servidor de Azure: arranque en frío de 117 ms en promedio (meta 1.5 s) y confirmación de inscripción en ~0.2 s (meta 2 s).

Ajustes al backlog durante el proyecto:

- **RF-16 y TT-13:** decían "push con FCM". Se implementó con WorkManager, sin Firebase (ver 8.3).
- **RF-17:** pasó de lista estática a favoritos que avisan de lo nuevo, a pedido de la socia.
- **RF-02:** el filtro por ciudad se mantiene. "Cerca de mí" con la ubicación aproximada se cambió (20 oct.) por "Buscar cerca de" en el mapa: la familia escribe un lugar o toca un punto, y la app ya no pide permiso de ubicación. El mapa ahora incluye los centros del Directorio.
- **Nuevos, salidos de la revisión final contra los requerimientos y la rúbrica:**
- RF-29: consulta sin conexión con Room.
- Lista de "quiénes van" para la asociación: completa RF-06.
- Pantalla para atender solicitudes de eliminación: completa RF-15 y HU-14.
- Foto con cámara.

Quedó fuera (y se dice):

- iOS.
- Pagos.
- Mensajería entre familias.
- Inscribirse o donar sin conexión.
- Notificaciones instantáneas por FCM.
- Correo real en producción (hoy Mailpit; basta configurar `SMTP_*`).

8.2 Bitácora de hitos

Hito	Fecha prevista	Fecha real	Cumplimiento
Establecimiento de requerimientos	19/08/2026	20/08/2026	1 día tarde

Hito	Fecha prevista	Fecha real	Cumplimiento
Casos de uso y prototipo (Figma)	31/08/2026	24/08/2026	A tiempo
Esqueleto de la app (tema, dominio, navegación)	—	21/09/2026	—
RF imprescindibles e importantes (RF-01 a RF-11, RF-17 a RF-21)	14/09/2026	01/10/2026	17 días tarde
Entrega 2: app funcional y backlog	01/10/2026	01/10/2026	A tiempo, con datos simulados en memoria
RF de la segunda ola (RF-12 a RF-16, RF-22, RF-23)	08/10/2026	05/10/2026	A tiempo (en la app; el backend llegó después)
Base de datos en Docker	08/10/2026	07/10/2026	A tiempo
Backend completo (API, monitoreo, túnel)	—	13/10/2026	No estaba planeado como hito
Identidad propia con JWT y ABAC (se quita Auth0)	—	15/10/2026	Cambio de rumbo (8.3)
Refresh tokens, revisión de testimonios, recuperación por correo, avisos del servidor, ZAP con sesión	—	16/10/2026	—
Cierre de pendientes del backlog (RNF-02, TT-15, TT-16)	08/10/2026	16/10/2026	8 días tarde
Sin conexión, cámara, "quiénes van", eliminación desde la app, documentación final y despliegue en Azure	22/10/2026	19 al 21/10/2026	A tiempo
Entrega 3 y presentación final	22/10/2026	22/10/2026	—

8.3 Desviaciones entre lo planeado y lo ejecutado

Desviación	Causa	Efecto y cómo se resolvió
La Entrega 2 se cerró con datos en memoria, sin backend	Se priorizó enseñar la experiencia completa a la socia	La integración, el cupo concurrente y la seguridad se concentraron en la última semana y media

Desviación	Causa	Efecto y cómo se resolvió
Identidad: Auth0 del 13 al 15 de octubre y luego JWT propio	Se eligió Auth0 por el diagrama del profesor antes de leer el anexo de identidad del curso y la guía s23, que piden emitir los tokens propios	Dos días de retrabajo (migración V7, app, pruebas, guía). A cambio, refresh tokens rotados y bloqueo por correo propios
Notificaciones con WorkManager en lugar de FCM (RF-16, TT-13)	FCM pide cuenta de Google, Play Services y otra llave en el servidor, y obliga a declarar a Google en el aviso de privacidad; la Práctica 8 enseña a hacerlo sin Firebase	Los avisos llegan con hasta ~15 min de retraso. Aceptado y documentado
Favoritos dinámicos (RF-17)	La socia cambió el concepto: debía avisar de lo nuevo	Se reabrió RF-17 y se conectó con RF-22
Plataformas: de Android e iOS a solo Android	Tiempo del reto y lo visto en el curso	Decisión del equipo; no se formalizó con la socia. iOS queda como siguiente paso
Alertas por cercanía con GPS (*geofencing*, caso de uso del documento de requerimientos)	Privacidad (dilema 1, §9.4) y tiempo: pedir la ubicación y seguirla no se justificaba para ordenar una lista	"Buscar cerca de" con un lugar que la familia escribe, y avisos por intereses y urgencias de la ciudad (RF-22), sin ubicación

Desviación	Causa	Efecto y cómo se resolvió
Ajustes pedidos por la socia (duplicar eventos, estilos, "Donar" en lugar de "Apartar")	Revisiones con la socia	Tareas To-do 2 a 5 en Planner, completadas del 5 al 7 de octubre
Servidor en Azure for Students en lugar de Oracle Cloud	Oracle rechazó la tarjeta en dos cuentas; la suscripción de estudiante de Azure solo permite cinco regiones (ninguna en México) y el primer tamaño elegido no tenía capacidad	Un día de pruebas de cuentas y regiones. Quedó en North Central US con Standard_B2als_v2, y el aviso de privacidad se actualizó para declarar dónde está el servidor
Se agregaron pantallas que el backlog daba por hechas ("quiénes van", atender eliminaciones, fichas sin conexión)	La revisión final contra los requerimientos y la rúbrica mostró que el servidor guardaba los datos pero nadie podía consultarlos desde la app	Implementadas con sus pruebas el 19 de octubre

8.4 Riesgos

Riesgo	Acción tomada	Resultado
Backend no listo a tiempo	Docker Compose desde el primer día del backend; pruebas automáticas contra servicios reales	Backend completo el 13/10 con 180+ pruebas; hoy 191 en verde
Contraseñas y roles de prueba en el código	RNF-02 y TT-15: contraseñas fuera del código, admin por permisos firmados en el token	Se corrigió el atajo `correo.contains("admin")` (guía §9.4); búsqueda de secretos sin hallazgos
Sobrecupo por solicitudes simultáneas	Reserva atómica con `SELECT … FOR UPDATE`	La prueba con 8 familias a la vez nunca sobrepasa el cupo; sin el candado entraban 5 en 3 lugares

Riesgo	Acción tomada	Resultado
Datos de menores (inscripciones, testimonios, fotos)	Consentimiento del tutor, revisión antes de publicar, fotos sin EXIF, lista de asistentes sin correos	Cada control con su prueba (§9)
Cambios de requerimientos de la socia	Preguntas registradas y backlog actualizado	Se absorbieron Favoritos y Donar
Gastar el crédito de estudiante antes de tiempo	VM de 2 vCPU (~37 USD/mes con disco e IP); apagarla (`az vm deallocate`) fuera de las demostraciones; borrar el grupo de recursos al terminar	Alcanza para más de 2 meses encendida; sin tarjeta no hay cobros
Disco lleno en la computadora que corre Docker	Cachés y herramientas movidas a otro disco; ZAP instalado en lugar de su imagen	Docker se cayó una vez (13/10) y se recuperó; el servidor de la demo ya no depende de esa computadora
La dirección del túnel cambia y deja al APK sin servidor	Servidor siempre encendido en Azure; procedimiento de recompilación documentado	Riesgo aceptado para la demo; con dominio propio se elimina (túnel con nombre)
Autoría de commits no refleja quién hizo qué	Evidencia de la distribución en Planner (8.5)	Ver retrospectiva

8.5 Distribución del trabajo

El reparto se planeó y se siguió en Planner: cada requerimiento, historia y tarea tiene responsable. Requerimientos y casos de uso se trabajaron entre los cinco.

Integrante	Tareas en Planner	Responsabilidades (ID del backlog)
Alberto López Barragán (A00841178)	20	Directorio, fichas y contacto (RF-01, RF-03, RF-08), proyectos y campañas (RF-09), información para donar (RF-10), insignias (RF-14), aviso de privacidad y eliminación (RF-15, HU-14, TT-14), panel y CRUD de administración (HU-02, TT-05, TT-12), navegación (TT-02), Android 10+ (RNF-05)
José Andrés Fajardo Martínez (A00842793)	20	Cupo en tiempo real e inscripción con acompañantes (RF-05, RF-06, RF-25, HU-07, TT-11), testimonios con revisión (RF-12, HU-11), notificaciones y avisos (RF-16, RF-22, HU-13, TT-09, TT-13), métricas de impacto (RF-23), ViewModels (TT-07), rendimiento (RNF-01, RNF-07)
Gael Alexander Zaragoza Torres (A01385956)	20	Cuenta y sesión (RF-18, RF-24, HU-01, TT-01), perfil e historial (RF-11), favoritos (RF-17, RF-27, HU-10, TT-08), filtros y apartado en campañas (RF-20, RF-21, HU-05), centros de donación (HU-06), UiState (TT-06), navegación con Atrás (RNF-04)
Bárbara Martínez Mijares (A01723424)	18	Ciudad y "Cerca de mí" (RF-02, RF-26), actividades y detalle (RF-04, HU-03), calendario (RF-07, HU-08, TT-10), encabezado (HU-04), componentes de UI (TT-04), estados de pantalla (RNF-06), secretos fuera del código (RNF-02, TT-15)
Damaris Paola Castrellón Carrillo (A01234497)	10	Encuestas (RF-13, HU-12), cancelación hasta 12 h (RF-19, RF-28, HU-09), estado al rotar (RNF-03), modelo de dominio y datos de prueba (TT-03)

Sobre el historial de Git: varias aportaciones se integraron desde la cuenta de Alberto o desde una misma computadora, así que el número de commits y de líneas por autor no refleja quién hizo cada parte. Por ejemplo, un integrante aparece con dos nombres distintos. La evidencia de la distribución es Planner. El archivo `.mailmap` del repositorio agrupa las identidades de cada persona para que `git shortlog` sea legible.

8.6 Retrospectiva

Qué funcionó

1. **Probar contra los servicios de verdad.** Las pruebas del servidor corren contra PostgreSQL, Redis y el almacén reales, no contra simulaciones. Así aparecieron dos fallas que una prueba con simulaciones no habría visto: - el límite global de

peticiones no frenaba nada por una incompatibilidad de slowapi con FastAPI 0.143; - quitando el `FOR UPDATE`, entraban 5 familias en 3 lugares.

2. **Un estado de pantalla común (`UiState`) desde la Entrega 2.** Permitió trabajar las pantallas en paralelo con los mismos estados de cargando, vacío y error, y la integración con la API no obligó a rehacerlas.
3. **Diseñar primero los casos límite** (último lugar, meta agotada, sin conexión) en el prototipo. Cuando llegó el servidor, ya había pantalla para cada respuesta de error.
4. **Una bitácora de decisiones con fecha.** Cada vez que una decisión se reemplazó (Auth0 → JWT, testimonios sin revisión → con revisión), quedó escrito por qué. Eso sostuvo la defensa técnica.

Qué no funcionó

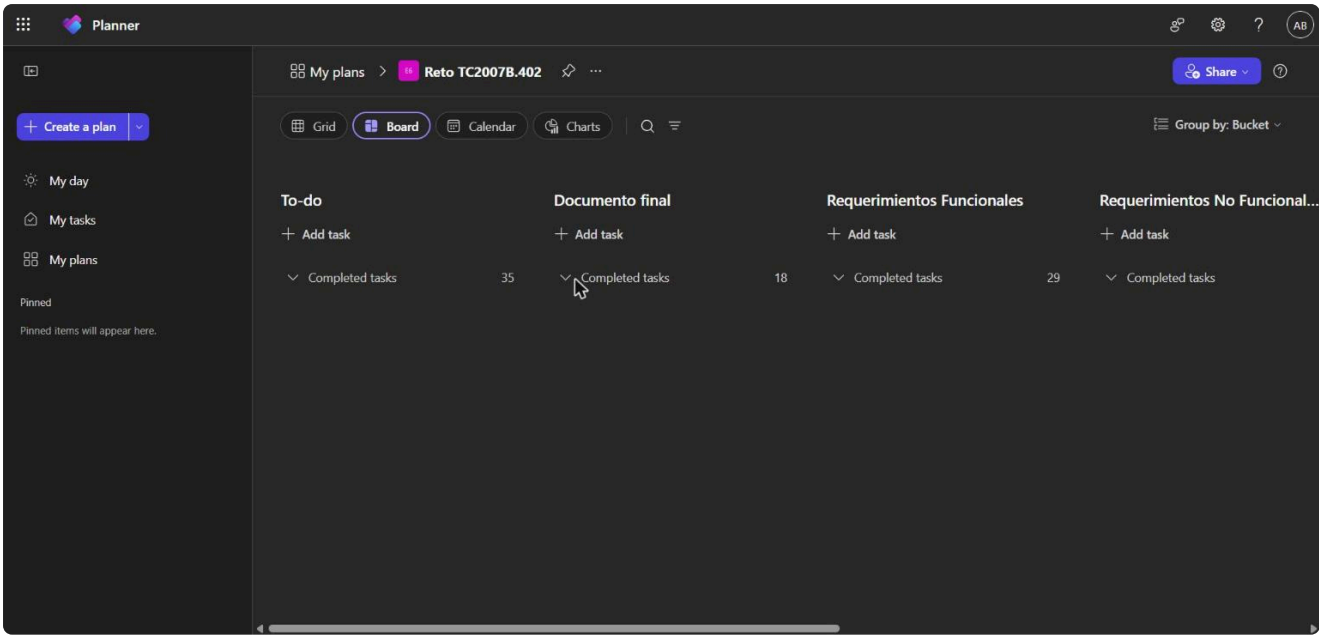
1. **Dejar el backend para el final.** La Entrega 2 con datos en memoria hizo que la integración, la seguridad y la concurrencia se juntaran en diez días. Algunos requisitos estaban "hechos" en la app pero el servidor no los respaldaba; por ejemplo, la asociación no tenía cómo ver la lista de asistentes.
2. **Elegir tecnología antes de leer los anexos del curso.** Auth0 se integró y se quitó en dos días porque el anexo de identidad pedía emitir tokens propios.
3. **Planner al final.** Los RNF, historias y tareas técnicas se capturaron casi al cierre, y las tareas del documento final seguían "sin iniciar" a una semana de la entrega. Lo del backend, la seguridad y el despliegue ni se dio de alta: se agregó como tareas retroactivas el 22 de octubre. Planner dejó de servir para anticipar y se volvió un registro.
4. **Commits desde una cuenta compartida.** El historial no muestra el trabajo de cada quien.
5. **Atajos en el cliente.** El rol de administrador salió primero de "el correo contiene *admin*". Se corrigió, pero ningún proceso lo habría detectado antes de la revisión de seguridad.
6. **Construir antes de validar con la socia.** Favoritos se hizo estático y hubo que rehacerlo cuando ella explicó que debía avisar de lo nuevo.

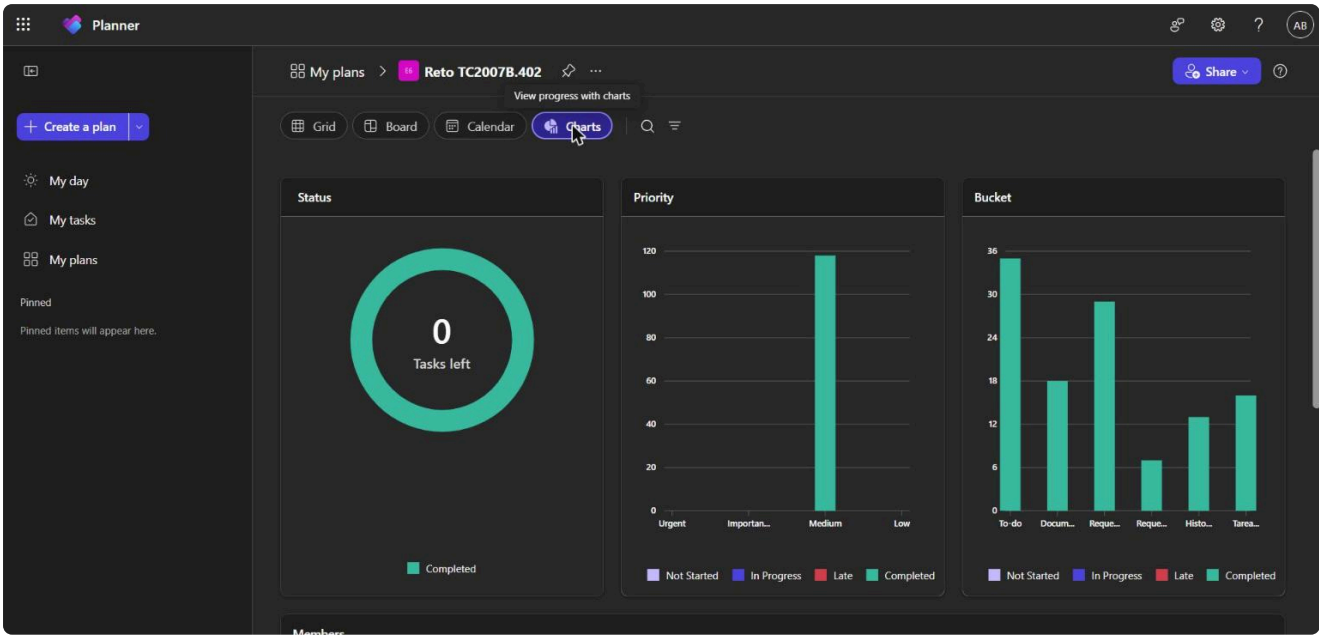
Qué cambiaríamos en un proyecto similar

Problema	Práctica nueva
Backend tardío	Desde la semana 1, un contrato OpenAPI y un servidor mínimo en Docker. La app consume la API real (aunque devuelva datos fijos) desde el primer sprint
Tecnología sin revisar	Antes de adoptar una herramienta externa, revisar los anexos y guías del curso y escribir la decisión en la bitácora con su alternativa
Planner como registro	Cada tarea nace con su criterio de aceptación y la prueba que la demostrará. "Terminado" = prueba en verde + fila en la matriz
Autoría invisible	Cada quien commitea con su cuenta y su correo, por *pull request* revisado por otra persona
Atajos de seguridad	Una revisión de seguridad por sprint (aunque sea corta), con OWASP ZAP y la lista de controles de la rúbrica
Validación tardía	Mostrar a la socia un prototipo navegable de cada función nueva antes de programarla
Dirección del servidor que cambia	Conseguir un dominio y un túnel con nombre al inicio, no al final

8.7 Captura del tablero de Planner

Estado del plan **Reto TC2007B.402** el 22 de octubre de 2026, al cerrar la entrega: 118 tareas, todas completadas (de ellas, 12 se dieron de alta ese día como «(retroactivo)», ver el inicio de este capítulo). Enlace al plan en la sección 10.


Planner
AB
My plans
Reto TC2007B.402
Share
Create a plan
Grid
Board
Calendar
Charts
Group by: Bucket
My day
My tasks
My plans
Pinned
Pinned items will appear here.
To-do
Add task
Completed tasks 35
Documento final
Add task
Completed tasks 18
Requerimientos Funcionales
Add task
Completed tasks 29
Requerimientos No Funcional...
Add task
Completed tasks


Planner
AB
My plans
Reto TC2007B.402
Share
View progress with charts
Create a plan
Grid
Board
Calendar
Charts
My day
My tasks
My plans
Pinned
Pinned items will appear here.
Status
0
Tasks left
Completed
Priority
120
100
80
60
40
20
0
Urgent
Importan...
Medium
Low
Not Started
In Progress
Late
Completed
Bucket
36
30
24
18
12
6
0
To-do
Docum...
Reque...
Reque...
Histo...
Tarea...
Not Started
In Progress
Late
Completed

9. Consideraciones éticas y legales

9.0 Ética, moral y ley en el desarrollo de la app

Usamos las distinciones del módulo de Sentido Humano:

- **Moral:** el conjunto de costumbres y normas que una comunidad considera buenas para regular el comportamiento.
- **Ética:** la disciplina que estudia la moral y justifica las decisiones, sobre todo cuando la ley no alcanza o hay valores en conflicto.
- **Ley:** la norma jurídica general y exigible, dentro de la jerarquía Constitución → códigos y leyes → reglamentos → normas.

Ámbito	Qué significa en este proyecto	Cómo se convirtió en algo del sistema
Ley (exigible)	LFPDPPP (DOF 20-03-2025, última reforma DOF 14-11-2025): aviso de privacidad, consentimiento, seguridad, derechos ARCO. Ley General de los Derechos de Niñas, Niños y Adolescentes, art. 76 (vida privada y datos personales de menores). Código Penal Federal, arts. 211 bis 1 a 211 bis 7 (acceso ilícito a sistemas)	Aviso integral y simplificado; aceptación del aviso para crear la cuenta; consentimiento del tutor para inscribir menores; eliminación de datos con folio y plazos de ley; controles contra el acceso no autorizado
Moral (lo que la comunidad de Familias que Suman considera correcto)	Cuidar a las familias y a los menores, no exponer a nadie, no lucrar con la ayuda	Testimonios revisados antes de publicarse; sin mensajería entre familias; sin listas públicas de quién ayuda; la donación es informativa, sin cobros
Ética (justificar cuando hay conflicto)	Utilidad de la app frente a privacidad, autonomía y sostenibilidad	Los dilemas de §9.4: ubicación, testimonios con menores, notificaciones sin terceros, qué guardar sin conexión, qué conservar al eliminar una cuenta

Sostenibilidad (Agenda 2030). La app atiende el ODS 10 (reducir desigualdades) y el ODS 11 (comunidades sostenibles) al conectar a familias con causas locales. También el ODS 17 (alianzas): le da visibilidad a organizaciones pequeñas que no tienen cómo publicar sus necesidades, como registramos en la guía de observación de la OSF. Del lado técnico se cuida el consumo:

- las fotos se reducen a 1600 px antes de subirse;
- los avisos se revisan en un solo trabajo cada 15 minutos que Android agrupa;
- no hay servicios de terceros duplicados;
- el servidor es una sola VM pequeña (2 núcleos, 4 GB) que se apaga cuando no se usa.

Delitos cibernéticos. Los riesgos del módulo que aplican a esta app y lo que hace cada control:

Riesgo	Control
Acceso ilícito a datos (art. 211 bis del CPF)	Autorización por recurso, fuerza bruta bloqueada, auditoría (§4)
Doxing o difusión de datos de una familia	Lo público nunca incluye correos ni teléfonos de las familias; los testimonios salen con el nombre de la familia
Grooming	No hay mensajería entre usuarios, y la lista de asistentes solo la ve quien tiene el permiso de registrar asistencias

Riesgo	Control
Suplantación	Nadie se registra como administración; los permisos van firmados en el token

9.1 Criterios éticos y legales convertidos en requisitos verificables

ID del backlog	Criterio (ámbito)	Requisito verificable	Criterio de aceptación	Prueba o evidencia	Referencia en la matriz
RF-15	Informar antes de tratar los datos (Ley: LFPDPPP arts. 14, 15 y 16-II)	La app muestra el aviso integral (art. 15, fr. I a VI) en Ajustes y el simplificado al crear la cuenta; sin aceptarlo no se crea	`POST /v1/sesion/registro` sin `acepta_aviso` responde 422 `aviso_requerido`	`test_identidad.py::test_registro_pide_el_aviso_de_privacidad` ; pantalla `AvisoPrivacidadScreen`	§3.1 RF-15
HU-14, TT-14	Derecho de cancelación (Ley: LFPDPPP arts. 24 y 31)	La familia pide la eliminación desde la app y recibe un folio; la administración la atiende y se borran cuenta, acompañantes, inscripciones, encuestas, testimonios y fotos	Tras atenderla, la cuenta no existe, su token deja de servir y queda solo la constancia (folio, correo, fecha)	`test_participacion.py::test_solicitud_de_eliminacion_es_idempotente_y_la_atiende_privacidad` ; M-15	§3.1 RF-15, §3.4 HU-14
RF-06	Datos de menores con consentimiento de su tutor (Ley: LFPDPPP art. 7; LGDNNA art. 76)	Inscribir a un menor exige el consentimiento de quien lo inscribe, y se guarda cuándo se dio	Sin consentimiento: 422 `falta_consentimiento` ; con él: 200 y `consentimiento_menores_en`	`test_inscripciones.py::test_menores_piden_consentimiento`	§3.1 RF-06
RF-06	Minimización (Ley: LFPDPPP art. 12; Ética)	La asociación ve quiénes van solo con nombre y edad, y solo quien registra asistencias	La lista no contiene ningún correo; una familia o el admin del catálogo reciben 403	`::test_quien_registra_asistencias_ve_quienes_van_sin_correos` , `::test_una_familia_o_el_admin_del_catalogo_no_ven_quienes_van`	§3.1 RF-06
RF-12, HU-11	Cuidado del otro: no exponer a menores (Moral)	Ningún testimonio ni su foto es público hasta que la OSF lo aprueba; editarlo lo regresa a revisión	Un testimonio nuevo no aparece en `GET /v1/testimonios` ; su foto solo la ven su autora y la moderación	`test_testimonios.py::test_un_testimonio_nuevo_no_es_publico_hasta_aprobarlo` , `::test_la_foto_en_revision_solo_la_ven_su_autora_y_la_moderacion`	§3.1 RF-12
RF-12	Las fotos no delatan dónde viven (Ética; Ley: art. 18)	Toda foto se re-codifica sin EXIF (GPS incluido), en el teléfono y otra vez en el servidor	La foto guardada no tiene EXIF	`test_fotos.py::test_foto_valida_se_guarda_sin_exif` ; `Fotos.prepararParaSubir`	§3.1 RF-12
RF-02	Ubicación mínima y opcional (Ética; Ley: art. 12)	La app no pide la ubicación: "Buscar cerca de" usa un lugar que la familia escribe o toca en el mapa	Ninguna ruta de la API recibe ubicación de la familia; el manifiesto no pide permisos de ubicación; a OpenStreetMap solo va el texto escrito, sin token	`CercaniaTest` (6); M-02; `AndroidManifest.xml`	§3.1 RF-02
RNF-02, SEG-02	Seguridad de los datos (Ley: LFPDPPP art. 18; CPF art. 211 bis)	Contraseñas con Argon2id, códigos como HMAC, sesión del teléfono cifrada, ningún secreto en el repositorio	La base no contiene la contraseña; la búsqueda de secretos no encuentra nada	`::test_la_contrasena_se_guarda_como_hash_argon2id` , `test_recuperacion.py::test_el_codigo_no_se_guarda_en_claro` ; `docs/evidencia/secretos.txt`	§3.2 RNF-02, §3.3 SEG-02

ID del backlog	Criterio (ámbito)	Requisito verificable	Criterio de aceptación	Prueba o evidencia	Referencia en la matriz
SEG-03	Nadie ve lo ajeno (Ley: art. 18; Moral)	Una familia no puede leer ni borrar datos de otra	404 en cualquier recurso ajeno	`test_autorizacion.py::test_bola_no_se_ven_ni_se_borran_acompanantes_ajenos`	§3.3 SEG-03
RF-18	No revelar quién tiene cuenta (Ética)	Iniciar sesión y recuperar responden igual exista o no el correo	Mismo código y mensaje en los dos casos	`::test_mismo_mensaje_si_el_correo_no_existe_o_la_contrasena_esta_mal`, `test_recuperacion.py::test_responde_lo_mismo_exista_o_no_la_cuenta`	§3.1 RF-18
RF-10	No lucrar con la ayuda (Moral)	La app no procesa pagos ni pide datos financieros	No hay pantalla de pago ni dependencia de pagos	Revisión de `app/build.gradle.kts` y de las pantallas de Donar; M-10	§3.1 RF-10
RF-29	Lo que se guarda en el teléfono es solo lo público (Ética; Ley: art. 12)	Sin conexión solo se consulta el catálogo público, nunca datos de la familia	La tabla `respuestas` de Room solo guarda rutas públicas	`CatalogoLocalTest`; `CatalogoLocal.kt` (lista de claves)	§3.1 RF-29

9.2 Aviso de privacidad

Fundamento: Ley Federal de Protección de Datos Personales en Posesión de los Particulares (DOF 20-03-2025):

- **art. 15:** contenido mínimo del aviso, fracciones I a VI;
- **art. 16, fracción II:** aviso simplificado cuando los datos se obtienen por medios electrónicos;
- **art. 14:** obligación de informar;
- **art. 18:** medidas de seguridad;
- **arts. 21 a 33:** derechos ARCO; el art. 31 fija los plazos.

Es el mismo texto que la app muestra en Perfil → Ajustes → Aviso de privacidad. El simplificado (puntos 1 a 4) aparece al crear la cuenta.

> **Aviso de privacidad integral · App Familias que Suman** (actualizado el 20 de octubre de 2026)
>
> **1. Quién es responsable** *(art. 15-I)*. Familias que Suman, asociación civil, con domicilio en Monterrey, Nuevo León, México. Para cualquier tema de tus datos: hola@familiasquesuman.com. Este aviso es el de la app; el de las actividades y el sitio está en familiasquesuman.com/aviso-de-privacidad.
>
> **2. Qué datos guardamos** *(art. 15-II)*.
>
> - **De la cuenta:** tu correo; tu contraseña, guardada como huella Argon2id (nadie puede leerla); el nombre de tu familia; tu nombre, fecha de nacimiento y sexo; tu ciudad; y, si la subes, tu foto de perfil.
> - **De tu familia:** nombre, fecha de nacimiento o edad y sexo de quienes registras como acompañantes. Si son menores de edad, guardamos que tú, como madre, padre o tutor, diste tu consentimiento.
> - **De tu participación:** inscripciones, asistencias, favoritos, ajustes de avisos, encuestas, testimonios con foto y sugerencias.

No pedimos datos sensibles: salud, religión, origen, preferencias, datos financieros ni biométricos.

3. Para qué los usamos *(art. 15-III)*.

- **Necesarias para el servicio:**
- crear tu cuenta e identificarte;
- mandarte a tu correo el código para cambiar tu contraseña cuando lo pides;
- inscribirte a actividades y avisar a quien organiza cuántas personas van y de qué edades;
- registrar tu asistencia y armar tu historial;
- proteger la app contra abusos.
- **Voluntarias (solo si tú las usas):** publicar tu testimonio, contestar encuestas para mejorar las actividades, recibir recordatorios y avisos de tu ciudad, y mandar sugerencias.

No usamos tus datos para publicidad.

4. Cómo limitar su uso *(art. 15-IV)*. En Ajustes apagas los recordatorios y avisos. Testimonios, encuestas, sugerencias y foto de perfil son opcionales y puedes borrarlos. La app no pide tu ubicación. Y puedes pedir que borremos todo.

Dónde se guardan. En nuestro servidor, una máquina de Microsoft Azure en Estados Unidos (región North Central US): la base de datos PostgreSQL y un almacén propio para las fotos. Microsoft solo presta la máquina: no usa ni consulta tus datos. En tu teléfono solo quedan:

- tu sesión, cifrada con una llave del propio teléfono;
- tus ajustes;
- el catálogo público (actividades, asociaciones, proyectos y campañas), para consultarlo sin internet.

Quién más los ve.

- El equipo de Familias que Suman que lo necesita para su trabajo; por ejemplo, quien registra la asistencia.
- Solo para coordinar una actividad, la institución que la organiza: recibe lo indispensable, como los nombres y edades de quienes van.
- Un servicio de correo, para mandar el código de tu contraseña: solo recibe tu dirección y ese mensaje.
- Cloudflare, para que la app llegue al servidor de forma cifrada.
- Microsoft Azure, que es donde está el servidor (en Estados Unidos).

Los servicios técnicos actúan como encargados y no usan tus datos para nada más. No vendemos tus datos. Solo los entregaríamos a una autoridad que los pida conforme a la ley.

Tu ubicación. La app no pide permiso de ubicación: no sabemos dónde estás. En el mapa puedes "Buscar cerca de" un municipio, una colonia o una calle que tú escribes (o un punto que tocas): los municipios se encuentran en el teléfono y lo demás se busca en OpenStreetMap, que solo recibe ese texto, sin tu cuenta ni tus datos. No lo guardamos. El mapa del Inicio dibuja las calles con OpenStreetMap: tu teléfono les pide las imágenes de la zona que estás viendo, sin tu ubicación ni tus datos.

Fotos y testimonios. Antes de publicarse, el equipo los revisa; mientras tanto solo los ves tú. Al publicarse aparecen con el nombre de tu familia, nunca con tu correo. Antes de subirse, a las fotos se les quita la ubicación y otros metadatos. Puedes eliminarlos cuando quieras.

Cómo los cuidamos *(art. 18)*. Todo viaja por HTTPS. En el servidor, cada cuenta solo puede ver lo suyo, los intentos de adivinar contraseñas se bloquean y queda una bitácora de las acciones sensibles (con una huella de la IP, no la IP).

Cuánto tiempo los guardamos. Mientras tengas tu cuenta. La sesión del teléfono vence a los 30 días sin uso. Al eliminar tu cuenta se borran tus datos, los de tus acompañantes, tus inscripciones, encuestas, testimonios y fotos. Se conserva:

- la constancia de tu solicitud (folio, correo y fecha), como bloqueo conforme al art. 24;
- la bitácora de seguridad, que no tiene tu nombre.

Tus sugerencias se quedan sin tu nombre ni tu contacto.

Tus derechos ARCO *(art. 15-V; arts. 21 a 33)*.

- **Acceso y rectificación:** tus datos están en Perfil, y ahí los corriges.
- **Cancelación:** el botón **Solicitar eliminación de mis datos** genera un folio.
- **Oposición, o cualquier duda:** escribe a hola@familiasquesuman.com con tu folio o el correo de tu cuenta.

Te respondemos en un máximo de 20 días y, si procede, se hace efectivo en los 15 días siguientes (art. 31). Si no te respondemos, puedes acudir a la Secretaría Anticorrupción y Buen Gobierno.

Si este aviso cambia *(art. 15-VI)*. Publicaremos la nueva versión en esta pantalla, con su fecha, y lo anunciaremos en la app antes de que aplique.

Cómo se comprueba que el aviso dice la verdad (la rúbrica pide que corresponda con el sistema):

Lo que promete	Dónde se ve en el sistema
Contraseña como huella Argon2id	`identidad.py` ; `test_la_contrasena_se_guarda_como_hash_argon2id`
Consentimiento del tutor	`inscripciones.consentimiento_menores_en` ; `test_menores_piden_consentimiento`
Sin ubicación de la familia	El manifiesto no pide permisos de ubicación; `BuscadorDeLugares.kt` manda solo el texto, sin token (`CercaniaTest`)
Testimonios revisados y sin correo	`test_testimonios.py` ; `test_los_testimonios_publicos_no_exponen_correos`
La institución ve nombres y edades	`GET /v1/admin/actividades/{id}/inscritos` (sin correos); pantalla "Quiénes van"
Eliminación con folio y plazos	Botón en la app → `ELIM-xxxx` ; pantalla "Solicitudes de eliminación"; `admin.py::atender` borra en cascada y las fotos del almacén
Fotos sin metadatos	`Fotos.prepararParaSubir` y `imagenes.py` ; `test_foto_valida_se_guarda_sin_exif`
En el teléfono solo lo público	`CatalogoLocal.kt`
Bitácora con huella de la IP	`auditoria.ip_hmac` (HMAC-SHA256)

Pendiente de la OSF: publicar su razón social y domicilio completos. El sitio todavía no los muestra, y el art. 15-I los pide. Se cambian en un solo lugar (`Responsable` , en `AvisoPrivacidadScreen.kt`).

9.3 Clasificación de los datos (campo por campo)

Niveles:

Nivel	Qué incluye
Crítico	Credenciales y secretos: dan acceso a la cuenta o al sistema
Alto	Datos personales de menores, o que permiten localizar o identificar a una familia
Medio	Datos personales de adultos y de su participación
Bajo	Seudónimos y preferencias
Público	Lo que cualquiera ve sin cuenta

Protección común a todo el servidor:

- TLS en el camino público y redes de Docker internas, sin acceso desde internet;
- PostgreSQL con un usuario de la API de mínimo privilegio;
- autorización por recurso (ABAC) y respaldos.

Columnas: dato · nivel · ubicación · protección específica · tiempo de conservación.

Cuenta (tabla `cuentas`)

Dato	Nivel	Ubicación	Protección específica	Conservación
`correo`	Medio	Servidor, `cuentas.correo`	Solo lo ve su dueña y quien atiende la privacidad; nunca sale en respuestas públicas	Mientras exista la cuenta
`contrasena_hash`	Crítico	`cuentas.contrasena_hash`	Huella Argon2id con sal; la contraseña nunca se guarda ni se registra	Mientras exista la cuenta
`nombre_familia`	Medio	`cuentas.nombre_familia`	Sale en testimonios publicados (aprobados)	Mientras exista la cuenta
`titular_nombre`	Medio	`cuentas.titular_nombre`	Solo su dueña y la lista de "quiénes van"	Mientras exista la cuenta
`titular_nacimiento`	Medio	`cuentas.titular_nacimiento`	Se usa para calcular la edad mínima; no se muestra a terceros	Mientras exista la cuenta
`titular_sexo`	Medio	`cuentas.titular_sexo`	Opcional; solo su dueña	Mientras exista la cuenta
`ciudad`	Bajo	`cuentas.ciudad` y `PreferenciasStore` en el teléfono	—	Mientras exista la cuenta
`foto_clave` (foto de perfil)	Alto	Almacén RustFS; copia en el teléfono (`filesDir/perfil`)	Re-codificada sin EXIF; solo la ve su dueña	Hasta que la quite o elimine la cuenta

Dato	Nivel	Ubicación	Protección específica	Conservación
`rol`, `permisos`	Crítico (autorización)	`cuentas`; firmados dentro del JWT	Solo se cambian en el servidor (`herramientas.py`); cambiarlos invalida los tokens viejos	Mientras exista la cuenta
`aviso_aceptado_en`	Bajo	`cuentas`	Prueba del consentimiento	Mientras exista la cuenta
`ultimo_acceso_en`, `creada_en`	Bajo	`cuentas`	—	Mientras exista la cuenta
`tokens_validos_desde`	Bajo	`cuentas`	Corta todos los tokens anteriores	Mientras exista la cuenta

Familia e inscripciones

Dato	Nivel	Ubicación	Protección específica	Conservación
`acompanantes.nombre`	Alto (pueden ser menores)	`acompanantes`	Solo su dueña (BOLA → 404)	Hasta que lo quite o elimine la cuenta (cascada)
`acompanantes.fecha_nacimiento` / `edad`	Alto	`acompanantes`	Solo su dueña; se usa para la edad mínima	Igual
`acompanantes.sexo`	Alto	`acompanantes`	Opcional; solo su dueña	Igual
`inscripcion_personas.nombre`, `edad`, `fecha_nacimiento`, `sexo`	Alto	`inscripcion_personas`	Lo ve su dueña y quien tiene `registrar:asistencias` (nombre y edad, sin contacto; consulta auditada)	Mientras exista la cuenta (cascada)
`inscripciones.consentimiento_menores_en`	Medio	`inscripciones`	Prueba del consentimiento del tutor	Mientras exista la cuenta
`inscripciones.personas`, `creada_en`, `cancelada_en`	Bajo	`inscripciones`	—	Mientras exista la cuenta
`asistencias` (quién fue a qué)	Medio	`asistencias`	Solo la registra quien tiene `registrar:asistencias`	Mientras exista la cuenta
`favoritos`	Bajo	`favoritos`; copia en `FavoritosStore` del teléfono	—	Hasta que los quite o elimine la cuenta
`preferencias` (recordatorios, urgencias)	Bajo	`preferencias`; copia en `PreferenciasStore`	—	Mientras exista la cuenta
`aportaciones` (qué se comprometió a donar)	Medio	`aportaciones`	Idempotentes; no se muestra quién aportó	Mientras exista la cuenta
`invitaciones`	Bajo	`invitaciones`	Solo un conteo	Mientras exista la cuenta

Participación y contenido

Dato	Nivel	Ubicación	Protección específica	Conservación
`testimonios.experiencia`	Medio	`testimonios`	No es público hasta aprobarse; sale con el nombre de la familia, sin correo	Hasta que lo borre o elimine la cuenta

Dato	Nivel	Ubicación	Protección específica	Conservación
`testimonios.foto_clave`	Alto (puede mostrar menores)	Almacén RustFS; caché del teléfono	Sin EXIF; en revisión solo la ven su autora y la moderación	Igual; se borra del almacén al eliminar la cuenta
`respuestas_encuesta.respuestas`	Medio	`respuestas_encuesta`	Solo su dueña y la moderación	Mientras exista la cuenta
`sugerencias.sugerida_por`, `contacto`	Medio	`sugerencias`	Solo la administración	Al eliminar la cuenta se borran (queda la sugerencia anónima)
`sugerencias.descripcion`, `organizacion`	Bajo	`sugerencias`	Solo la administración	Indefinida (son sobre causas, no sobre la familia)

Sesión, recuperación y seguridad

Dato	Nivel	Ubicación	Protección específica	Conservación
JWT de acceso	Crítico	Teléfono (`sesion_jwt`)	AES-256-GCM con llave del Android Keystore; firmado HS256	15 minutos
Refresh token	Crítico	Teléfono (cifrado); en el servidor solo su huella (`sesiones.huella`)	Rotación y un solo uso; reusarlo cierra la sesión	30 días sin uso, o hasta cerrar sesión
Tokens revocados	Bajo	Redis	Contraseña de Redis; red interna	Hasta que vence el token
`recuperaciones.huella` (código de 6 dígitos)	Crítico	`recuperaciones`	Se guarda como HMAC, no el código; 5 intentos; un solo uso	Vence a los 15 min; la fila se borra con la cuenta
Intentos fallidos por correo	Bajo	Redis	La clave es el SHA-256 del correo, no el correo	15 minutos
`auditoria.ip_hmac`	Bajo (seudónimo)	`auditoria`	HMAC-SHA256 de la IP: sin la llave no se recupera la IP	Indefinida. Pendiente: definir un plazo (propuesta: 12 meses)
`auditoria.actor_id`, `accion`, `detalle`	Medio	`auditoria`	La API solo puede agregar renglones: no editarlos ni borrarlos (`test_minimo_privilegio.py`); sin nombres	Indefinida (misma propuesta)
`solicitudes_eliminacion.correo`, `folio`	Medio	`solicitudes_eliminacion`	Solo quien atiende la privacidad	Indefinida, como constancia y bloqueo (art. 24)

Solo en el teléfono

Dato	Nivel	Ubicación	Protección específica	Conservación
Lugar de "Buscar cerca de" (lo que se escribe o se toca)	Bajo	Memoria de la app, nunca en disco	No es la ubicación del teléfono; a OpenStreetMap va solo el texto, sin token ni correo	Lo que dura la pantalla
Correo de la sesión e inscripciones (copia para el worker)	Medio	`CuentasStore` (SharedPreferences privadas)	Sandbox de la app; `allowBackup=false`	Hasta cerrar sesión

Dato	Nivel	Ubicación	Protección específica	Conservación
Bandeja de avisos	Bajo	`AvisosStore`	Sandbox	Hasta cerrar sesión o desinstalar
Catálogo público	Público	Room `catalogo.db`	—	Se reemplaza en cada consulta con red
Foto de la cámara antes de subirla	Alto	Caché `camara/`	Compartida con la app de cámara solo por FileProvider; se borra en la siguiente foto	Hasta la siguiente foto

Catálogo (público)

Nombre, descripción, dirección, teléfono y correo **de las asociaciones, proyectos, campañas y centros** (no de familias). Nivel **Público**. Se guardan en el servidor y en la caché del teléfono. Solo la administración del catálogo los modifica, y se conservan mientras estén vigentes.

9.4 Dilemas éticos y decisiones de diseño

Dilema 1 · Ubicación: utilidad frente a privacidad

- **El dilema.** RF-02 pide "lo que está cerca de mí". Para ordenar por cercanía hace falta saber dónde está la familia, pero la ubicación de una familia con hijos es de los datos más delicados que puede tener una app.
- **Alternativas:**
- (a) GPS preciso enviado al servidor, que ordena y puede sugerir;
- (b) solo elegir la ciudad a mano;
- (c) ubicación aproximada, calculada solo en el teléfono y solo cuando se pide;
- (d) no pedir la ubicación: la familia escribe o toca el lugar desde el que quiere buscar.
- **Argumentos:**
- (a) da el mejor orden y permite avisos por cercanía, pero crea un registro de dónde está cada familia, que se puede filtrar o pedir;
- (b) no expone nada, pero no cumple el criterio de RF-02;
- (c) cumple el criterio con el mínimo dato (LFPDPPP art. 12), aunque el orden es menos fino y no hay avisos por cercanía;
- (d) cumple el criterio sin ningún dato de ubicación, y además sirve para buscar cerca del trabajo o de la escuela, no solo de donde está el teléfono; a cambio, la familia escribe un lugar.
- **Postura del equipo:** primero fue (c); en la revisión final (20 oct.) pasamos a (d). "Un dato que no se recibe no se puede filtrar", y uno que ni siquiera se pide, menos.
- **Decisión concreta:**
- el manifiesto no pide ningún permiso de ubicación;
- "Buscar cerca de" vive en el mapa del Inicio: los municipios de las dos ciudades se resuelven en el teléfono; una colonia o calle se busca en OpenStreetMap (`BuscadorDeLugares.kt`), que solo recibe el texto y la ciudad, sin token ni correo;
- la distancia se calcula en el teléfono (`porCercania`, haversine) y ninguna ruta de la API recibe coordenadas de la familia.

- **Dónde se ve:** el campo "Buscar cerca de" del mapa; `AndroidManifest.xml`; `CercaniaTest`; aviso de privacidad, "Tu ubicación".

Dilema 2 · Testimonios con fotos de niñas y niños: participación frente a protección

- **El dilema.** Los testimonios con foto motivan a otras familias y son lo que la OSF quiere mostrar. Pero muchas fotos tienen menores, y publicarlas sin filtro puede exponerlos (LGDNNA art. 76; riesgo de *grooming* y *doxing*). Además, la foto de un teléfono lleva las coordenadas de dónde se tomó.
- **Alternativas:**
- (a) publicar al enviar y moderar después;
- (b) prohibir las fotos;
- (c) revisión previa por la OSF, foto sin metadatos y sin datos de contacto.
- **Argumentos:**
- (a) es inmediato y menos trabajo para la OSF, pero lo dañino ya se vio;
- (b) protege del todo, pero quita lo que más valor tiene para la socia;
- (c) conserva el valor y protege, a costa de trabajo de moderación y de que la familia espere.
- **Postura del equipo:** (c). El daño a un menor no se deshace al borrar la foto. La decisión original ("se publican al enviarse") se **reemplazó** el 16 de octubre (`docs/bitacora.md`).
- **Decisión concreta:**
- estados `pendiente` → `aprobado` / `rechazado`, y editar un testimonio lo regresa a revisión;
- solo `moderar:contenido` revisa;
- la foto en revisión solo la ven su autora y la moderación;
- toda foto se re-codifica sin EXIF en el teléfono y en el servidor;
- lo publicado sale con el nombre de la familia, nunca con su correo.
- **Dónde se ve:** Perfil → Testimonios (admin); `test_testimonios.py`; `test_foto_valida_se_guarda_sin_exif`; aviso de privacidad, "Las fotos y testimonios".

Dilema 3 · Notificaciones: inmediatez frente a no depender de terceros

- **El dilema.** Las urgencias ("se necesitan 5 voluntarios") valen más si llegan al instante. La forma estándar es Firebase Cloud Messaging, que hace pasar cada aviso por Google.
- **Alternativas:**
- (a) FCM;
- (b) WorkManager que pregunta al servidor propio cada 15 minutos.
- **Argumentos:**
- (a) entrega al instante con la app cerrada, pero pide cuenta de Google, Play Services y otra llave privada en el servidor, y el aviso de privacidad tendría que declarar a Google como encargado;
- (b) no comparte nada con terceros y funciona en teléfonos sin Play Services, pero puede tardar ~15 minutos o más (Doze).
- **Postura del equipo:** (b), como en la Práctica 8. Para avisos de voluntariado, unos minutos de retraso no ponen a nadie en riesgo; compartir con un tercero quién recibe qué aviso sí cambia lo que la familia aceptó.

- **Decisión concreta:**
- `RevisarAvisosWorker` cada 15 minutos;
- `GET /v1/avisos?desde=` con la sesión;
- recordatorios calculados en el teléfono con el catálogo público;
- el riesgo queda aceptado y escrito en la guía (§15).
- **Dónde se ve:** `RevisarAvisosWorker.kt`; Ajustes (interruptores); `test_avisos.py`; aviso de privacidad, "Quién más los ve" (no aparece Google).

Dilema 4 · Qué conservar cuando una familia pide borrar sus datos

- **El dilema.** La familia tiene derecho a que se borren sus datos (art. 24). La OSF quiere conservar las sugerencias de nuevas causas que mandó, y necesita una constancia de que atendió la solicitud.
- **Alternativas:**
- (a) borrar todo, incluidas sugerencias y constancia;
- (b) borrar la cuenta pero conservar todo lo demás con su nombre;
- (c) borrar todo lo personal, conservar la sugerencia sin nombre ni contacto, y una constancia mínima.
- **Argumentos:**
- (a) es lo más radical, pero pierde información útil para la comunidad y la prueba de cumplimiento;
- (b) conserva datos personales contra la voluntad de la titular;
- (c) respeta el derecho y conserva lo que no es de la persona.
- **Postura del equipo:** (c).
- **Decisión concreta:**
- `atender` borra la cuenta en cascada y sus fotos del almacén;
- las sugerencias quedan como "Familia que eliminó su cuenta", sin contacto;
- la solicitud se queda con folio, correo y fecha (bloqueo, art. 24).
- **Dónde se ve:** pantalla "Solicitudes de eliminación"; `admin.py::atender`; aviso de privacidad, "Cuánto tiempo los guardamos".

Dilema 5 · Sin conexión: comodidad frente a datos en el teléfono

- **El dilema.** El equipo se comprometió (RF-29) a consultar las fichas sin conexión. Lo más cómodo sería guardar todo en el teléfono, incluidas inscripciones y perfil. Pero un teléfono se pierde o se presta, y ahí quedarían nombres y edades de los hijos.
- **Alternativas:**
- (a) guardar todo;
- (b) no guardar nada;
- (c) guardar solo el catálogo público.

- **Postura del equipo:** (c). Cumple el compromiso sin crear una copia de datos personales fuera del servidor. Además, el cupo guardado no se presenta como real.
- **Decisión concreta:** Room con una sola tabla de respuestas de rutas públicas (`CatalogoLocal.kt`); franja "Sin conexión · estás viendo lo guardado el…"; "Lugares no disponibles sin conexión".
- **Dónde se ve:** modo avión en la app (M-OFF); `CatalogoLocalTest` ; aviso de privacidad, "Dónde se guardan".

10. Enlaces de la entrega

Qué	Enlace
Repositorio, versión entregada	https://github.com/albertolopezb/familias-que-suman/tree/entrega-final
APK de release firmado	https://drive.google.com/drive/folders/1osTVnL2wIYpvCL74rTf3JJoNcdxOEZq0 (carpeta `APK_firmado_Equipo6`, archivo `familias-que-suman-v3.2.apk`, versión 3.2 (versionCode 5), 17,514,068 bytes, SHA-256 `94c9cdcaedf85d182ba36ff4bebad299cc4c137cab8175fa16c8fcd55bd804c2`)
Backend: instrucciones para levantarlo	Manual de instalación, §6.2 y §6.3 y `backend/README.md`
Backend: servicio desplegado	https://hunter-marilyn-larger-frequent.trycloudflare.com/v1/salud (VM de Azure for Students, `northcentralus`; es la dirección que trae el APK. Si el túnel se reinicia cambia: ver Manual de instalación §6.3)
Video de respaldo de la demostración (≈3 min)	https://drive.google.com/drive/folders/1bQLPZ2NHcXp1g29H75r_nojWvFdAHnlh?usp=sharing (carpeta `Video_respaldo`, archivo `Video_demostracion.mp4`)
Plan de Planner	https://planner.cloud.microsoft/ui/web/plan/jledDqTkHUOzxWWQ96dCqmQAE0ku/view/board?tid=c65a3ea6-0f7c-400b-8934-5a6dc1705645 (plan «Reto TC2007B.402»; requiere cuenta del Tec con acceso). Captura del tablero final en la sección 8.7
Acuerdo de requerimientos con el socio formador	No hay un acta independiente (ver §1.1): *Requerimientos Iniciales Validados* (Canvas, RF-01 a RF-15) y *Requerimientos Equipo 6* (abajo)
Requerimientos y decisiones del equipo	https://docs.google.com/document/d/1E9YGMQR1R2KuULSeeNgVbwip-9pn6ljhmjwBu2FMb7o
Prototipo (Figma)	https://www.figma.com/design/MHJNZRX0wO86ZFuWTJiwzR/Familias-que-Suman-%E2%80%94-Prototipo